

Instituto Tecnológico y de Estudios Superiores de Occidente

Caso de Estudio

Desconocimiento de la Ley de Protección de Datos Personales
en el sector de nutrición y propuesta de solución

Cristian Emanuel Ortega Camarena

Enero 2026

Índice

Resumen Ejecutivo	5
1. Introducción	5
1.1. Contexto del sector de nutrición en México	5
1.2. Planteamiento del problema	6
1.3. Objetivos general y específicos	6
1.4. Alcance (qué incluye y qué excluye)	6
1.5. Preguntas guía	6
2. Marco Normativo: Protección de Datos Personales	6
2.1. La Ley Federal de Protección de Datos Personales (LFPDPPP)	6
2.1.1. Antecedentes y origen	7
2.1.2. México y la protección de datos: entre compromisos internacio- nales y necesidades internas	9
2.1.3. Estructura de la ley, sujetos obligados y principios rectores	12
2.1.4. Sanciones y mecanismos de denuncia: de la teoría a la realidad institucional	15
2.2. Análisis comparativo internacional: Brasil, Uruguay, Estados Unidos y Alemania	18
2.2.1. Brasil: LGPD (Lei 13.709/2018)	19
2.2.2. Uruguay: Ley 18.331/2008	21
2.2.3. Estados Unidos: HIPAA, HITECH y el modelo de responsabili- dad compartida	24
2.2.4. Alemania: GDPR, BDSG, PDSG y el estándar de nube en salud más exigente del mundo	27
2.2.5. Cuadro comparativo regional	30
2.3. Análisis crítico de la ley mexicana	34
2.3.1. Fortalezas del marco normativo mexicano	34
2.3.2. Debilidades: la ambigüedad técnica y las ausencias estructurales	37
2.4. Traducción de la ley a requerimientos de software: Privacy by Design	40
2.4.1. Privacy by Design: el concepto y su relación con la LFPDPPP	40
2.4.2. De artículo legal a requerimiento técnico: tabla de trazabilidad normativa	43
2.4.3. Requerimientos que la ley mexicana no exige pero el estándar internacional sí: decisiones de diseño proactivas	46
3. Diagnóstico: Situación Actual del Sector	47

3.1.	Hábitos digitales del nutriólogo en México	47
3.1.1.	Diseño de encuesta a nutriólogos	47
3.1.2.	Resultados y métricas base del problema	48
3.2.	Estudio de mercado y competencia	48
3.2.1.	Softwares actuales de nutrición en México	48
3.2.2.	Benchmarking de seguridad: carencias de la competencia	48
3.2.3.	Diferenciador de NutriApp	48
4.	Marco de Referencia Técnico	49
4.1.	Arquitectura en la nube: conceptos y estándares	49
4.2.	Seguridad de datos: cifrado, MFA y trazabilidad	49
4.3.	Privacy by Design: principios y aplicación práctica	49
4.4.	Estándares internacionales aplicables (ISO/IEC 27001, HIPAA como referencia)	49
5.	Metodología	49
5.1.	Tipo de estudio y enfoque metodológico	49
5.2.	Investigación documental: análisis normativo y benchmarking	49
5.2.1.	Criterios de selección y revisión del marco legal	49
5.2.2.	Criterios de benchmarking de software de nutrición	50
5.3.	Investigación de campo: encuestas a nutriólogos	50
5.3.1.	Población objetivo y criterios de inclusión	50
5.3.2.	Diseño y validación de instrumentos	50
5.3.3.	Procedimiento de aplicación y recolección de datos	50
5.3.4.	Estrategia de análisis y triangulación	50
5.4.	Diseño arquitectónico basado en evidencia	50
5.4.1.	Trazabilidad: de requisito legal a decisión técnica	50
5.4.2.	Alcance y limitaciones del diseño propuesto	50
5.5.	Consideraciones éticas y confidencialidad	51
6.	Diseño de la Solución	51
6.1.	Infraestructura AWS: KMS, Cognito, Lambda, RDS	51
6.2.	Diagramas de ingeniería	51
6.2.1.	Diagrama de arquitectura de servicios	51
6.2.2.	Diagramas UML: casos de uso y secuencia	51
6.2.3.	Diagrama entidad-relación	51
7.	Propuesta del Producto Mínimo Viable (MVP)	51
7.1.	Requerimientos mínimos del sistema	51
7.2.	Módulo de consentimiento digital y derechos ARCO	52

7.3. Justificación del alcance del MVP	52
8. Resultados y Análisis	52
8.1. Resultados de encuestas: evidencia del desconocimiento	52
8.2. Validación normativa del diseño propuesto	52
8.3. Análisis costo-beneficio: prevención de multas vs. costo operativo	52
9. Conclusiones	52
9.1. Comprobación de hipótesis	52
9.2. Lecciones aprendidas y recomendaciones para el gremio	52
9.3. Limitaciones del estudio y trabajo futuro	53
Referencias	53
Anexos	57

Resumen Ejecutivo - en construcción

El sector de la nutrición en México presenta un desconocimiento generalizado de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP). En términos generales, la LFPDPPP es el marco jurídico que regula cómo debe tratarse la información de clientes y pacientes. Su objetivo principal es garantizar que cada persona tenga el poder de decidir quién posee sus datos, para qué se utilizan y quién puede consultarlos.

Dentro de la práctica clínica cotidiana se observa que una gran cantidad de nutriólogos gestionan la información de sus pacientes —clasificada por la ley como datos personales sensibles— a través de herramientas de ofimática como hojas de cálculo. Estas herramientas generalmente carecen de protocolos de seguridad, cifrado y trazabilidad, por lo que no permiten cumplir las obligaciones técnicas y administrativas dictadas por la normativa vigente, exponiendo tanto al profesional como a los pacientes a riesgos legales y de privacidad.

La LFPDPPP solicita “medidas de seguridad” sin especificar cuáles, lo que permite que un nutriólogo agregue simplemente una contraseña al archivo donde lleva seguimiento de sus pacientes, cuando en contraste, en otros países esa misma acción sería considerada una negligencia grave.

En cuanto a la autorregulación, en México se asume que el licenciado en nutrición conoce la ley, pero no existe ninguna certificación que lo acredite ni ningún requisito obligatorio para las herramientas que usa en su día a día. En contraste, en países como Estados Unidos, si un software no es *HIPAA Compliant*, el profesional simplemente no puede utilizarlo sin arriesgar su licencia.

Los derechos ARCO son la vía por la cual el paciente ejerce soberanía sobre su información. En México, el nutriólogo tiene la obligación de responder estas solicitudes en no más de 20 días hábiles; sin embargo, los requerimientos limitados y ambiguos de la ley dificultan la elaboración de reportes completos y generan inconsistencias cuando la solicitud implica la eliminación del historial clínico.

1. Introducción

1.1. Contexto del sector de nutrición en México

1.2. Planteamiento del problema

1.3. Objetivos general y específicos

1.4. Alcance (qué incluye y qué excluye)

1.5. Preguntas guía

2. Marco Normativo: Protección de Datos Personales

Antes de proponer cualquier solución tecnológica, es necesario entender el terreno legal sobre el que opera. Esta sección presenta el marco normativo mexicano en materia de protección de datos personales, desde sus antecedentes constitucionales hasta la ley vigente en 2025, con un enfoque particular en lo que ese marco implica para el sector de la nutrición. Se analiza también el contexto que llevó a México a construir esta normativa, su comparación con otros países de la región y las implicaciones prácticas para cualquier profesional que maneje información clínica de pacientes.

2.1. La Ley Federal de Protección de Datos Personales (LFPDPPP)

La Ley Federal de Protección de Datos Personales en Posesión de los Particulares es el instrumento jurídico central de este caso de estudio. Entender qué es, cómo llegó a existir y qué obliga a hacer no es un ejercicio teórico: es el punto de partida para comprender por qué un nutriólogo que lleva sus expedientes en una hoja de cálculo está, sin saberlo, incumpliendo obligaciones legales concretas con consecuencias reales.

Las siguientes subsecciones recorren su origen, su contexto político, su estructura y su sistema de sanciones.

2.1.1. Antecedentes y origen

Para comprender la necesidad de una plataforma como NutriApp, es importante revisar cómo México fue construyendo su marco legal en materia de protección de datos personales. Este proceso no fue rápido ni lineal: tomó décadas, pasó por varios intentos fallidos y siempre estuvo un paso atrás de la realidad tecnológica del país. Los siguientes cinco hitos muestran esa evolución de forma cronológica.

I. 1917: El punto de partida, una Constitución pensada para otro mundo.

La Constitución de 1917 nació en un contexto muy diferente al que vivimos hoy. El artículo 16, en su versión original, protegía al ciudadano de intromisiones físicas por parte de la autoridad, estableciendo que *“Nadie puede ser molestado en su persona, familia, domicilio, papeles o posesiones, sino en virtud de mandamiento escrito de la autoridad competente, que funde y motive la causa legal del procedimiento”* (Constitución Política de los Estados Unidos Mexicanos [CPEUM], 1917/2024, art. 16). En ese momento, la única forma de vulnerar la información privada de alguien era accediendo físicamente a sus documentos. La posibilidad de que esos mismos datos pudieran ser robados o mal utilizados a través de una computadora simplemente no estaba en el horizonte de quienes redactaron esa ley, lo que dejó a la privacidad de las personas desprotegida frente a los riesgos que traería la era digital.

II. **2001–2009: Una década de intentos sin resultado.** Con el paso de los años y la llegada de internet a la vida cotidiana, quedó claro que la Constitución no era suficiente para proteger la información personal que ya circulaba en bases de datos privadas. Entre septiembre de 2001 y diciembre de 2009 se presentaron diversas propuestas de ley para regular el manejo de datos personales por parte de empresas y profesionistas, pero ninguna llegó a aprobarse (Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales [INAI], 2021, p. 14). Esta situación no es un detalle menor: una década sin avances legislativos explica por qué la ley que finalmente salió en 2010 llegó con huecos importantes. Las razones detrás de esa urgencia legislativa se analizan en la sección siguiente. Para sectores como el de la nutrición, que nunca habían tenido reglas claras en esta materia, esos huecos tendrían consecuencias concretas que se analizan más adelante en este documento.

III. **2007: El primer reconocimiento en la Constitución, pero solo para el**

gobierno. Antes de que los datos personales fueran reconocidos como un derecho de todas las personas, hubo un antecedente que suele pasarse por alto: la reforma de 2007 al artículo 6° constitucional. Con esta modificación, México reconoció por primera vez en su Constitución la protección de datos personales y el derecho de los ciudadanos a acceder y corregir su información, pero únicamente cuando esta estuviera en manos del gobierno (CPEUM, 1917/2024, art. 6°). Médicos, consultorios, nutriólogos y cualquier profesional independiente que manejara información de pacientes quedaron fuera. Este límite dejó en evidencia que proteger los datos frente al Estado no era suficiente; también hacía falta regular a los particulares.

IV. 2009: Los datos personales se convierten en un derecho de todas las personas. El cambio más importante llegó el 1 de junio de 2009, cuando se modificó el artículo 16 constitucional para reconocer que la información personal de cada individuo le pertenece y debe estar protegida. El texto establece que *“Toda persona tiene derecho a la protección de sus datos personales, al acceso, rectificación y cancelación de los mismos, así como a manifestar su oposición, en los términos que fije la ley”* (CPEUM, 1917/2024, art. 16). Con esto nacieron los Derechos ARCO, que son la vía mediante la cual cualquier persona puede decidir quién tiene su información, para qué se usa y cuándo debe eliminarse. Sin embargo, este reconocimiento seguía siendo una declaración de intenciones: la Constitución otorgaba el derecho, pero todavía no existía la ley concreta que estableciera las obligaciones para quienes manejan esa información ni las consecuencias de no cumplirlas.

V. 2010–2011: La ley y su reglamento, cuando las obligaciones se volvieron reales. Para que ese derecho constitucional tuviera efecto en la vida diaria, en 2010 se publicó la Ley Federal de Protección de Datos Personales en Posesión de los Particulares. A partir de ese momento, manejar expedientes de pacientes dejó de ser una práctica sin reglas para convertirse en una obligación legal que requería un Aviso de Privacidad y medidas de seguridad verificables. La ley fue clara al señalar que *“Tratándose de datos personales sensibles, el responsable deberá obtener el consentimiento expreso y por escrito del titular para su tratamiento”* (Ley Federal de Protección de Datos Personales en Posesión de los Particulares [LFPDPPP], 2010, art. 9). Un año después, en 2011, se publicó su Reglamento, que tradujo esas obligaciones en términos técnicos concretos. El artículo 57 estableció que los responsables debían usar *“herramientas que permitan la trazabilidad de las consultas, accesos y modificaciones realizados a los datos personales [...] y el control de acceso a los datos”* (Reglamento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares [RLFPDPPP], 2011,

art. 57). Para este caso de estudio, es particularmente relevante el artículo 52 del mismo Reglamento, que permite expresamente el uso de servicios de cómputo en la nube siempre que el proveedor ofrezca niveles de protección equivalentes a los que exige la ley mexicana (RLFPDPPP, 2011, art. 52). Este artículo es el fundamento legal que respalda el uso de **Amazon Web Services (AWS)** como infraestructura de NutriApp.

VI. 2025: Una nueva ley y un cambio institucional de fondo. En marzo de 2025 entró en vigor una nueva versión de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, que reemplazó formalmente a la de 2010 (LFPDPPP, 2025, Transitorio Segundo). En términos generales, los principios y los Derechos ARCO se mantienen, pero hay ajustes importantes para el sector salud. El artículo 9 precisa ahora que no es necesario el consentimiento del paciente cuando sus datos se requieren para brindarle atención médica y este no está en condiciones de otorgarlo (LFPDPPP, 2025, art. 9). Las sanciones también cambiaron: ya no se expresan en montos fijos sino en múltiplos de la Unidad de Medida y Actualización (UMA), y pueden llegar hasta 320,000 veces ese valor, con posibilidad de duplicarse cuando se trata de datos sensibles como los de salud (LFPDPPP, 2025, art. 59). El cambio más visible a nivel institucional es la desaparición del Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (INAI), cuyas funciones en materia de datos personales pasaron a la **Secretaría Anticorrupción y Buen Gobierno** (LFPDPPP, 2025, Transitorio Cuarto). Esto es relevante para cualquier nutriólogo: si recibe una solicitud de derechos ARCO o enfrenta una revisión por incumplimiento, la autoridad ante la que debe responder ya no es el INAI sino esta nueva dependencia, que aún está consolidando sus procesos en esta materia.

Lo que une a todos estos hitos es una ausencia constante: en ningún momento del proceso legislativo se desarrolló una estrategia de comunicación dirigida a los profesionales de salud independientes, como los nutriólogos de consulta privada. La ley se creó, se actualizó y finalmente se renovó, pero el gremio nunca recibió capacitación formal ni fue sujeto de ningún requisito obligatorio de cumplimiento. Esto convierte al desconocimiento no en una falla personal de cada profesional, sino en una omisión del sistema que este caso de estudio busca documentar y atender con una solución concreta.

2.1.2. México y la protección de datos: entre compromisos internacionales y necesidades internas

Entender por qué México tiene hoy una ley de protección de datos requiere mirar más allá del texto legal. Detrás de cada reforma hubo fuerzas concretas que la impulsaron:

compromisos económicos internacionales, demandas ciudadanas y decisiones políticas que fueron moldeando las instituciones que hoy regulan cómo se maneja la información de los mexicanos. Esta sección reconstruye ese proceso desde dos ángulos: la presión que llegó de afuera y la que se gestó desde adentro.

I. 1994: El ingreso a la OCDE y el costo de no proteger los datos. Cuando México ingresó a la Organización para la Cooperación y el Desarrollo Económicos el 18 de mayo de 1994, asumió algo más que compromisos de política económica (Organización para la Cooperación y el Desarrollo Económicos [OCDE], 1994). Ser parte de ese grupo de países significaba adoptar estándares que ya llevaban años construyéndose en Europa y Estados Unidos, incluyendo los relacionados con el manejo de información personal. Desde 1980, la OCDE había publicado sus directrices sobre privacidad y flujos transfronterizos de datos, un documento que establecía los principios mínimos que cualquier país miembro debía respetar para garantizar que la información de las personas pudiera circular de forma segura entre economías (OCDE, 1980). El fondo del asunto era comercial: si México no podía garantizar que los datos de sus ciudadanos y socios comerciales estarían protegidos, quedaba en desventaja frente a otros países en acuerdos de intercambio de información y comercio digital (OCDE, 1980). No se trataba de una exigencia moral sino de una condición práctica para participar en la economía global. Esta realidad explica, en parte, por qué las primeras iniciativas legislativas en México en materia de datos personales aparecieron justo en los años posteriores al ingreso a la OCDE, y también por qué la ley que finalmente se aprobó en 2010 fue diseñada con más urgencia que profundidad, como se señaló en la sección anterior.

II. 2002: La sociedad civil toma la iniciativa y nace el IFAI. Mientras la presión internacional empujaba desde afuera, dentro del país ocurría algo diferente. A principios de los años 2000, un grupo de periodistas y académicos conocido como el Grupo Oaxaca comenzó a exigir que el gobierno mexicano fuera más transparente sobre el uso de los recursos públicos y la toma de decisiones (Marván Laborde, 2023). Su trabajo impulsó la aprobación de la Ley Federal de Transparencia y Acceso a la Información Pública Gubernamental, publicada el 11 de junio de 2002 (Ley Federal de Transparencia y Acceso a la Información Pública Gubernamental [LFTAIPG], 2002). Esta ley trajo consigo la creación del primer antecedente directo del organismo regulador en materia de datos: el Instituto Federal de Acceso a la Información Pública (IFAI), constituido formalmente mediante decreto presidencial el 24 de diciembre de 2002 (LFTAIPG, 2002). En su diseño original, el IFAI era un organismo descentralizado de la administración pública federal, lo que significaba que operaba con cierta autonomía pero dentro

de la estructura del Ejecutivo. Su misión inicial era vigilar que el gobierno respondiera las solicitudes de información de los ciudadanos, no regular a empresas ni profesionistas independientes. Fue hasta 2010, cuando se aprobó la LFPDPPP, que el IFAI amplió su alcance al sector privado y ajustó su nombre para reflejar esa nueva responsabilidad (INAI, 2021).

- III. 2014–2015: Del IFAI al INAI, cuando la autonomía se volvió real.** Durante sus primeros años, el IFAI funcionó como parte de la administración pública. En la práctica, su independencia tenía límites claros: su presupuesto dependía del Ejecutivo y sus comisionados eran designados por el presidente. Con el tiempo quedó evidente que un organismo que debía vigilar al propio gobierno no podía depender de él para operar. Esa tensión fue el origen de una reforma que cambiaría su naturaleza por completo. El 7 de febrero de 2014 se publicó la reforma constitucional que le otorgó autonomía plena, es decir, dejó de depender del Ejecutivo y pasó a ser un organismo del Estado con independencia real para tomar decisiones sin estar sujeto a presiones políticas (Marván Laborde, 2023). Con ese cambio llegó también un nuevo nombre: el Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales, mejor conocido como INAI. Este no fue un simple cambio de nombre sino un rediseño institucional de fondo: la Ley General de Transparencia que lo respaldó, publicada el 4 de mayo de 2015, pasó de 64 a 214 artículos, amplió los sujetos obligados e incrementó las obligaciones de transparencia de forma considerable (Marván Laborde, 2023). Para el sector salud, esto significó que el INAI contaba ahora con herramientas reales para investigar, sancionar y resolver conflictos relacionados con el manejo de datos de pacientes.
- IV. 2025: La extinción del INAI y el cierre de un ciclo institucional.** La historia del organismo regulador terminó de forma abrupta. El 20 de diciembre de 2024 se publicó una reforma constitucional de simplificación orgánica que ordenó la extinción del INAI, y el 20 de marzo de 2025 esa decisión se concretó con la entrada en vigor de la nueva LFPDPPP (LFPDPPP, 2025, Transitorio Cuarto). Las funciones en materia de datos personales pasaron a la Secretaría Anticorrupción y Buen Gobierno, un organismo que depende directamente del Ejecutivo, lo que representa un retroceso en términos de independencia institucional respecto al modelo que se había construido desde 2014 (Marván Laborde, 2023). Para los nutriólogos y cualquier profesional de salud independiente, este cambio tiene una consecuencia práctica concreta: la autoridad ante la que deben responder si un paciente ejerce sus derechos ARCO o si enfrentan una revisión por incumplimiento ya no es el INAI sino esta nueva dependencia, que al momento de redactar este documento aún está consolidando sus procesos y criterios en la materia.

Lo que muestra este recorrido es que tanto la presión internacional como la demanda ciudadana fueron fuerzas necesarias para que México avanzara en la protección de datos. Sin embargo, en ninguno de esos momentos el gremio de la nutrición estuvo presente en la conversación, ni como sector que exigiera herramientas adecuadas ni como uno al que se le explicaran sus obligaciones. Esa ausencia es parte del origen del problema que este caso de estudio busca documentar.

2.1.3. Estructura de la ley, sujetos obligados y principios rectores

Conocer que existe una ley de protección de datos es solo el primer paso. Lo que realmente importa para este caso de estudio es entender qué dice esa ley, a quién le aplica y qué significa cumplirla en la práctica de un consultorio de nutrición. La LFPDPPP no es un documento pensado para abogados: es una obligación activa para cualquier persona que, en el ejercicio de su trabajo, reciba y guarde información de otras personas. Esta sección desglosa su núcleo en cinco puntos y lo cruza con el marco técnico y sanitario que lo complementa.

- I. **La ley aplica a todos los particulares que manejan datos, sin importar el tamaño del negocio.** El artículo 1 de la ley establece que su objeto es *“la protección de los datos personales en posesión de los particulares, con la finalidad de regular su tratamiento legítimo, controlado e informado, a efecto de garantizar la privacidad y el derecho a la autodeterminación informativa de las personas”* (LFPDPPP, 2025, art. 1). El artículo 2 define como sujetos regulados a las *“personas físicas o morales de carácter privado que llevan a cabo el tratamiento de datos personales”* (LFPDPPP, 2025, art. 2, fracc. XVI). Esto abarca desde una empresa transnacional hasta un nutriólogo que atiende pacientes de forma independiente. Las únicas dos excepciones son las sociedades de información crediticia y quienes recopilan datos para *“uso exclusivamente personal, y sin fines de divulgación o utilización comercial”* (LFPDPPP, 2025, art. 1). Guardar el historial clínico de un paciente para darle seguimiento no encaja en ninguna de esas dos excepciones, así que el nutriólogo de consulta privada está obligado desde el momento en que anota el primer dato de quien lo visita. Vale la pena aclarar que en México existe un segundo ordenamiento en la materia —la Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados (LGPDPPO)—, pero este aplica exclusivamente al sector gubernamental. Los organismos estatales de transparencia, como el ITEI en Jalisco, vigilan el acceso a información pública gubernamental, no el manejo de datos por profesionistas privados. El nutriólogo de consulta privada responde únicamente ante la LFPDPPP federal.

- II. **No todos los datos tienen el mismo nivel de protección, y los de sa-**

lud están en la categoría más alta. La ley distingue entre datos personales ordinarios y datos personales sensibles. Los primeros son *“cualquier información concerniente a una persona identificada o identificable”* (LFPDPPP, 2025, art. 2, fracc. V). Los segundos son aquellos que *“afecten a la esfera más íntima de la persona titular, o cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para esta”*, e incluyen expresamente *“el estado de salud presente o futuro”* y la *“información genética”* (LFPDPPP, 2025, art. 2, fracc. VI). El expediente de un paciente de nutrición —con su peso, diagnósticos, medicamentos, resultados de laboratorio y hábitos de vida— cae en esta segunda categoría sin discusión posible. Ser datos sensibles activa un régimen de obligaciones más estricto, con consecuencias legales proporcionales al riesgo que representa su mal manejo.

III. Ocho principios que definen si se cumple o no con la ley. El artículo 5 establece que *“el responsable deberá observar los principios de licitud, finalidad, lealtad, consentimiento, calidad, proporcionalidad, información y responsabilidad en el tratamiento de datos personales”* (LFPDPPP, 2025, art. 5). Estos no son aspiraciones: son el criterio con el que la autoridad determina si hubo o no incumplimiento cuando se presenta una queja. En la práctica del consultorio significan que el nutriólogo solo puede pedir la información que realmente necesita para atender al paciente, debe decirle para qué la usará, tiene que mantenerla actualizada y correcta, y es responsable de protegerla mientras esté bajo su resguardo. El artículo 13 lo refuerza señalando que *“el responsable velará por el cumplimiento de los principios de protección de datos personales establecidos por esta Ley, debiendo adoptar las medidas necesarias y suficientes para su aplicación”* (LFPDPPP, 2025, art. 13). Desconocer estos principios no exime de cumplirlos.

IV. Para datos de salud, el consentimiento escrito es obligatorio bajo dos leyes independientes. La LFPDPPP establece en su artículo 8 que el responsable *“deberá obtener el consentimiento expreso y por escrito de la persona titular para su tratamiento, a través de su firma autógrafa, firma electrónica, o cualquier mecanismo de autenticación que al efecto se establezca”* (LFPDPPP, 2025, art. 8). Esta misma obligación aparece, de forma independiente, en la Ley General de Salud, cuyo artículo 51 Bis 2° establece que el prestador de servicios de salud debe dejar constancia en el expediente clínico del consentimiento informado del paciente respecto a los procedimientos diagnósticos y terapéuticos ofrecidos (Ley General de Salud [LGS], 1984/2024, art. 51 Bis 2°). La concurrencia de estas dos fuentes no es redundante: significa que el nutriólogo que no cuenta con ese consentimiento firmado está en incumplimiento simultáneo de la LFPDPPP y de la Ley General de Salud, dos ordenamientos que tienen autoridades y vías de

sanción distintas. La LGS agrega además en su artículo 77 Bis 37 que el paciente tiene derecho a que su información se maneje bajo el principio de confidencialidad (LGS, 1984/2024, art. 77 Bis 37), mientras que el artículo 103 Bis 3 establece la obligación de salvaguardar la confidencialidad de los datos genéticos de cualquier paciente (LGS, 1984/2024, art. 103 Bis 3), lo que abarca perfiles nutricionales vinculados a condiciones hereditarias como la diabetes o la hipertensión.

V. El Reglamento y las Normas Oficiales Mexicanas: el estándar técnico que la ley no especifica pero que sí es obligatorio. Uno de los límites más señalados de la LFPDPPP es que exige medidas de seguridad sin definir cuáles son suficientes para cada sector. El Reglamento de la ley cubre parte de ese hueco al establecer que las medidas deben aplicarse “*con independencia del sistema de tratamiento*” (Reglamento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares [RLFPDPPP], 2011, art. 57), lo que significa que el criterio aplica igual a un software especializado que a una hoja de cálculo. El artículo 61 del mismo Reglamento obliga al responsable a elaborar un inventario de datos y sistemas, realizar un análisis de riesgos y ejecutar un análisis de brecha para identificar las medidas de seguridad faltantes (RLFPDPPP, 2011, art. 61). En el sector salud, la parte que cierra esa ambigüedad son las Normas Oficiales Mexicanas. La **NOM-004-SSA3-2012** establece los criterios técnicos y administrativos obligatorios para el expediente clínico en cualquier establecimiento de atención médica —público, social o privado— e incluye explícitamente las notas de nutrición como parte de los documentos que deben integrarlo, con obligación de conservarlo con confidencialidad durante un mínimo de cinco años (Norma Oficial Mexicana NOM-004-SSA3-2012, 2012). La **NOM-024-SSA3-2012** va más lejos: cuando el sistema de registro es electrónico, exige cifrado de la información, autenticación de usuarios mediante credenciales verificables, y trazabilidad de todos los accesos y modificaciones al expediente (Norma Oficial Mexicana NOM-024-SSA3-2012, 2012). Una hoja de cálculo convencional, con o sin contraseña, no cumple ninguno de esos tres requerimientos técnicos. Finalmente, la **NOM-008-SSA3-2017**, aplicable al tratamiento de sobrepeso y obesidad, obliga a llevar el expediente clínico conforme a la NOM-004 (Norma Oficial Mexicana NOM-008-SSA3-2017, 2017), extendiendo esas obligaciones técnicas a una parte central de la práctica nutricional.

Lo que define a este marco legal no es su complejidad sino su profundidad: la LFPDPPP establece los principios, el Reglamento define los procedimientos de seguridad, la Ley General de Salud refuerza el consentimiento y la confidencialidad, y las Normas Oficiales Mexicanas concretan los estándares técnicos para el expediente clínico. Los cuatro instrumentos son de observancia obligatoria e independiente, y todos apuntan al mismo

resultado: el nutriólogo que hoy lleva sus expedientes en una hoja de cálculo tiene un incumplimiento activo, no hipotético.

2.1.4. Sanciones y mecanismos de denuncia: de la teoría a la realidad institucional

Conocer la ley y sus principios es solo una parte del panorama. La otra es entender qué pasa cuando no se cumple: quién lo detecta, cómo se denuncia, cuánto cuesta el error y qué tan probable es que alguien efectivamente pague las consecuencias. En el caso del sector salud en México, la respuesta a esas preguntas ha cambiado con el tiempo, y hoy se encuentra en un punto de transición que genera más preguntas que certezas.

I. Lo que la ley dice que puede pasar. La LFPDPPP vigente establece un esquema de sanciones escalonado según la gravedad de la infracción. Para las faltas más comunes, como no atender una solicitud ARCO sin justificación o actuar con negligencia en su trámite, la ley contempla multas de entre 100 y 160,000 veces la Unidad de Medida y Actualización (LFPDPPP, 2025, art. 59, fracc. II). Para infracciones más graves, como manejar datos sin consentimiento, vulnerar la seguridad de una base de datos o incumplir el deber de confidencialidad, el rango sube a entre 200 y 320,000 veces la UMA (LFPDPPP, 2025, art. 59, fracc. III). Con el valor de la UMA en 2025 fijado en \$113.14 pesos diarios, eso significa que una sanción grave puede alcanzar los \$36,204,800 pesos en su techo máximo. Y aquí viene el detalle que más importa para el sector nutrición: cuando las infracciones involucran datos sensibles como el estado de salud de un paciente, la ley establece que *“las sanciones podrán incrementarse hasta por dos veces los montos establecidos”* (LFPDPPP, 2025, art. 59, fracc. IV). En el peor escenario, eso representa más de 72 millones de pesos para un profesional que, en muchos casos, opera con los ingresos de un consultorio independiente. La ley también contempla sanciones penales: de tres meses a tres años de prisión para quien, estando autorizado para manejar datos, provoque una vulneración con ánimo de lucro, y de seis meses a cinco años cuando el engaño sea el medio para obtenerlos (LFPDPPP, 2025, arts. 62 y 63). Para datos sensibles, esas penas se duplican (LFPDPPP, 2025, art. 64).

II. Lo que realmente pasó mientras el INAI existió. Los números de la época del INAI muestran que el sistema sí funcionaba, aunque de forma selectiva. En 2022, el Instituto impuso multas por un total de \$60,078,958 pesos a personas físicas y morales que incumplieron la LFPDPPP, con 119 Procedimientos de Imposición de Sanciones iniciados, de los cuales 78 llegaron a conclusión con multa (Instituto Nacional de Transparencia, Acceso a la Información y Protección de

Datos Personales [INAI], 2023a, p. 1). En el mismo año se iniciaron 249 Procedimientos de Protección de Derechos en el sector privado, y se presentaron 1,068 denuncias por uso indebido de datos, de las cuales 901 fueron atendidas y concluidas, es decir, el 84.4 % tuvo una resolución (INAI, 2023a, p. 2). En el primer semestre de 2023, las multas sumaron \$11,020,991 pesos adicionales, con 52 nuevos procedimientos de sanción iniciados en ese solo periodo (INAI, 2023b, p. 1). Lo que estos números revelan no es que el INAI fuera perfecto, sino que cuando el sistema funcionaba, el sector salud pagaba una parte desproporcionada de la factura: en el primer semestre de 2023, el sector de servicios de salud y asistencia social concentró el 35.28 % del total de multas impuestas, posicionándose como el segundo sector más sancionado del país, solo detrás de servicios financieros (INAI, 2023b, p. 1).

III. **Los casos que le pusieron cara al problema.** Detrás de esas estadísticas hay situaciones concretas que ilustran exactamente los riesgos que corre un profesional de la salud independiente. En 2017, el INAI inició un procedimiento sancionador contra un médico que entregó a un tercero el expediente del estado de salud mental de su paciente sin autorización. El instituto determinó que el profesional no solo violó el deber de confidencialidad, sino que tampoco había informado a la paciente sobre el aviso de privacidad ni cumplía con los elementos que la ley exige en ese documento (Saludiaro, 2017, párr. 3). Un año después, en 2018, el INAI sancionó a un hospital con dos multas que sumaron \$4,600,000 pesos por negarse a entregar el expediente clínico a una paciente que lo solicitó tras el nacimiento de su hijo. La institución nunca respondió la solicitud, lo que el INAI calificó como negligencia grave en el trámite de derechos ARCO (Saludiaro, 2018, párr. 3). Ambos casos comparten una característica que los hace relevantes para este estudio: las conductas sancionadas no fueron actos maliciosos ni sofisticados, fueron exactamente las mismas omisiones cotidianas que comete cualquier profesional de la salud que opera sin conocer sus obligaciones legales: no tener aviso de privacidad, no pedir consentimiento por escrito, no responder solicitudes de acceso a datos. En palabras del propio INAI, el expediente clínico *“constituye un dato personal sensible, por lo que su resguardo y correcto uso es responsabilidad de los sujetos obligados, sin olvidar que el paciente es el dueño y titular”* de esa información (INAI, 2021, párr. 4).

IV. **La responsabilidad penal que ninguna capacitación en el gremio ha explicado.** El sistema de consecuencias no se limita a las multas administrativas. El Código Penal Federal establece en su artículo 210 que comete un delito quien *“sin justa causa, con perjuicio de alguien y sin consentimiento del que pueda resultar perjudicado, revele algún secreto o comunicación reservada que conoce o*

ha recibido con motivo de su empleo, cargo o puesto”, sancionado con treinta a doscientas jornadas de trabajo a favor de la comunidad (Código Penal Federal [CPF], 1931/2024, art. 210). Pero el artículo 211 del mismo código es el que aplica con mayor especificidad al profesional de la salud: establece que la sanción aumenta a uno a cinco años de prisión, multa y suspensión de la profesión de dos meses a un año *“cuando la revelación punible sea hecha por persona que presta servicios profesionales o técnicos”* (CPF, 1931/2024, art. 211). Esto significa que el nutriólogo certificado que, por negligencia o descuido, permite que los datos de salud de un paciente sean accedidos por terceros no autorizados —ya sea por compartir un archivo sin cifrado, por usar una cuenta de correo no segura o por no proteger su equipo— puede enfrentar responsabilidad penal en su condición de profesionista, no solo una multa administrativa. Esta exposición se refuerza por la Ley Reglamentaria del artículo 5° constitucional, que en su artículo 36 establece que todo profesionista está obligado a guardar secreto en los asuntos que le confíen sus clientes (Ley Reglamentaria del Artículo 5° Constitucional, Relativo al Ejercicio de las Profesiones en el Distrito Federal [Ley de Profesiones], 1945/2010, art. 36), obligación que incluye a los nutriólogos con cédula profesional y que existe de forma independiente a la LFPDPPP. La LFPDPPP agrega por su parte sanciones penales propias: de tres meses a tres años de prisión para quien, estando autorizado para manejar datos, provoque una vulneración con ánimo de lucro, y de seis meses a cinco años cuando el engaño sea el medio para obtenerlos (LFPDPPP, 2025, arts. 62 y 63). Para datos sensibles, esas penas se duplican (LFPDPPP, 2025, art. 64).

- V. **Marzo 2025: cuando la institución que sancionaba dejó de existir.** El 20 de marzo de 2025 el INAI fue extinto y sus funciones en materia de datos personales de particulares pasaron a la Secretaría Anticorrupción y Buen Gobierno, que opera bajo la estructura directa del Ejecutivo Federal (LFPDPPP, 2025, Transitorio Cuarto). La Secretaría señaló al momento de asumir las funciones que *“las relacionadas con la protección de datos personales quedarán bajo la responsabilidad directa de la propia Secretaría”* y que la operación se basaría en *“los principios de imparcialidad, eficiencia, legalidad y profesionalismo”* (Secretaría Anticorrupción y Buen Gobierno [SABG], 2025, párr. 3). En papel, la estructura existe: la Secretaría cuenta con una Dirección General de Datos Personales en el Sector Privado, auxiliada por tres direcciones especializadas en protección de derechos, atención a denuncias y procedimientos de sanciones (SABG, 2025, art. 30-F). En la práctica, al momento de redactar este documento no existe ningún registro público de procedimientos sancionadores concluidos ni de multas impuestas por esta nueva dependencia en materia de datos de particulares. El

propio sitio del INAI publicó un aviso señalando que “*este sitio ya no está vigente*” y que los contenidos relevantes “*se migrarán paulatinamente*” a las nuevas plataformas (INAI, 2025, párr. 1). Para el nutriólogo de Jalisco o de cualquier otro estado del país, esto significa que hoy opera en un entorno donde las obligaciones legales siguen vigentes e intactas, las sanciones potenciales no disminuyeron, pero la capacidad efectiva de la autoridad para investigar, resolver y cobrar multas es, por primera vez en más de una década, completamente desconocida.

Lo que muestra este recorrido no es que el riesgo haya desaparecido con la extinción del INAI: las obligaciones de la ley permanecen y cualquier paciente puede iniciar un procedimiento de protección de derechos en cualquier momento. Lo que sí cambió es la certeza sobre con qué velocidad y efectividad responderá la nueva autoridad. Para un gremio que nunca estuvo en el centro del debate sobre protección de datos, este momento de transición institucional representa tanto un riesgo como una oportunidad: el riesgo de seguir operando sin herramientas adecuadas mientras la autoridad se consolida, y la oportunidad de adoptar buenas prácticas antes de que el nuevo esquema sancionador encuentre su ritmo operativo.

2.2. Análisis comparativo internacional: Brasil, Uruguay, Estados Unidos y Alemania

El análisis que sigue no busca catalogar leyes extranjeras ni construir un inventario de regulaciones comparadas. Su propósito es más específico: identificar, en cada caso, qué hace un país diferente o mejor que México en materia de protección de datos de salud, usando siempre la LFPDPPP como eje de referencia. La pregunta guía no es qué dice cada ley, sino qué puede aprender México de ella. Para mantener ese enfoque, se seleccionaron cuatro marcos normativos con perfiles complementarios: Brasil, el más robusto de América Latina y referencia directa de lo que México podría ser; Uruguay, el más alineado a los estándares europeos en la región y prueba de que un marco sólido no requiere ser un país grande; Estados Unidos, cuyo modelo sectorial establece la responsabilidad del software de salud de una forma que México todavía no contempla; y Alemania, que representa el techo normativo mundial y cuya regulación de servicios en la nube tiene implicaciones directas para el diseño de NutriApp. La sección cierra con un cuadro comparativo de nueve criterios que sintetiza las diferencias más relevantes para este caso de estudio.

2.2.1. Brasil: LGPD (Lei 13.709/2018)

Brasil es el punto de comparación más cercano y más exigente para México dentro de la región. No porque sus realidades sean idénticas, sino porque los dos países llegaron a la protección de datos por caminos parecidos —presión internacional, demanda ciudadana, urgencia legislativa— y terminaron con resultados muy distintos. Entender qué hizo Brasil diferente es entender qué le falta a México.

I. Una ley construida desde el principio con el GDPR europeo como modelo, no como referencia lejana. La Lei Geral de Proteção de Dados Pessoais, publicada el 14 de agosto de 2018 y vigente desde septiembre de 2020, fue diseñada explícitamente a partir del Reglamento General de Protección de Datos de la Unión Europea (Lei Geral de Proteção de Dados Pessoais [LGPD], Lei 13.709/2018, art. 1º). Esto no es un detalle menor: mientras la LFPDPPP mexicana de 2010 se construyó con urgencia y dejó huecos importantes que su Reglamento intentó cubrir un año después, la LGPD brasileña incorporó desde su diseño original los diez principios del GDPR, la figura del Encargado de Proteção de Dados (equivalente al Data Protection Officer europeo), la evaluación de impacto a la privacidad y los mecanismos de responsabilidad proactiva y demostrada. En 2022, la Emenda Constitucional n° 115 elevó la protección de datos personales al rango de derecho fundamental en la Constitución Federal brasileña (Emenda Constitucional n° 115, 2022, art. 5º, LXXIX), equiparando a Brasil con el modelo europeo en el nivel más alto del ordenamiento jurídico. México realizó ese mismo reconocimiento constitucional en 2009 mediante la reforma al artículo 16 de la CPEUM, pero sin la profundidad técnica que Brasil construyó en los años siguientes.

II. La ANPD: lo que México tuvo con el INAI y perdió con la SABG. La Autoridade Nacional de Proteção de Dados (ANPD) fue creada por la propia LGPD como el organismo encargado de supervisar, fiscalizar y sancionar el cumplimiento de la ley (LGPD, 2018, arts. 55-A al 55-L). Su diseño institucional contempla independencia técnica y autonomía decisoria: sus directores tienen mandatos fijos de cuatro años, no pueden ser removidos por razones políticas y sus resoluciones no están sujetas a revisión del Ejecutivo. Este modelo es funcionalmente equivalente al que México construyó entre 2014 y 2025 con el INAI como organismo constitucional autónomo. La diferencia crítica es que Brasil mantiene ese modelo intacto, mientras que México lo desmanteló en marzo de 2025 al transferir las funciones del INAI a la Secretaría Anticorrupción y Buen Gobierno, un organismo que depende directamente del Ejecutivo Federal (LFPDPPP, 2025, Transitorio Cuarto). Para el nutriólogo que recibe una solicitud de derechos AR-

CO o que enfrenta una queja de un paciente, la diferencia es concreta: en Brasil la autoridad que resuelve es independiente del gobierno en turno; en México ya no lo es. Esta asimetría institucional es uno de los argumentos más sólidos para adoptar buenas prácticas de cumplimiento de forma proactiva, sin esperar a que la nueva autoridad mexicana consolide sus criterios y su ritmo sancionador.

- III. **Portabilidad de datos: un derecho que México no contempla explícitamente.** El artículo 18, fracción V de la LGPD establece el derecho del titular a la portabilidad de sus datos personales a otro proveedor de servicio o producto, mediante solicitud expresa y observando los secretos comerciales e industriales (LGPD, 2018, art. 18, inc. V). Este derecho no existe de forma explícita en la LFPDPPP mexicana vigente. Para el sector de la nutrición, la portabilidad tiene implicaciones prácticas directas: un paciente que cambia de nutriólogo debería poder solicitar que su expediente completo —con todo el historial de consultas, planes alimenticios y evolución clínica— sea transferido al nuevo profesional en un formato utilizable. En México, el derecho de cancelación y supresión existe, pero el derecho a que esos datos se transfieran activamente a un tercero no está regulado. NutriApp puede resolver esta brecha por diseño, incorporando la exportación estructurada del expediente como funcionalidad nativa, aun sin que la ley mexicana lo exija todavía.
- IV. **Notificación de brechas: estructura donde México tiene ambigüedad.** El artículo 48 de la LGPD establece que el controlador debe comunicar a la ANPD y a los titulares afectados la ocurrencia de un incidente de seguridad que pueda generar riesgo o daño relevante a los titulares, en un plazo razonable definido por la ANPD en regulación complementaria (LGPD, 2018, art. 48). La ANPD ha establecido en la práctica un plazo de referencia de setenta y dos horas para la notificación inicial a la autoridad. La LFPDPPP 2025 mexicana contempla la notificación de vulneraciones en su artículo 20, pero sin especificar un plazo concreto ni los elementos mínimos del reporte, lo que deja margen de ambigüedad que Brasil eliminó desde el diseño reglamentario de la ANPD.
- V. **El marco técnico en salud: más disperso que México, pero con una lógica diferente.** Una de las fortalezas singulares de México en este análisis es precisamente que las NOMs —en particular la NOM-004-SSA3-2012 y la NOM-024-SSA3-2012— constituyen el único marco técnico obligatorio y específico para el expediente clínico electrónico en toda la región. Brasil no tiene un equivalente único. El marco técnico en salud digital brasileño se construye a través de resoluciones del Conselho Federal de Medicina (CFM): la Resolución CFM 2.299/2021 regula los documentos médicos electrónicos y exige firma digital con certificados

ICP-Brasil; la Resolución CFM 2.314/2022 regula la telemedicina y establece que los datos clínicos del teleatendimiento deben seguir los lineamientos de la LGPD (Resolução CFM nº 2.314/2022, 2022, art. 6°). Esta arquitectura por resoluciones gremiales es más flexible que las NOMs mexicanas, pero también más fragmentada: no existe una norma única equivalente a la NOM-024 que establezca los requerimientos técnicos de cifrado, autenticación y trazabilidad para cualquier sistema de expediente clínico electrónico. En este punto concreto, México supera a Brasil en especificidad técnica obligatoria.

VI. Sanciones: proporcionadas a la capacidad económica del infractor. El modelo sancionador de la LGPD es cualitativamente diferente al de la LFPDPPP mexicana. Mientras México expresa sus multas en múltiplos de la Unidad de Medida y Actualización —un valor fijo que no considera el tamaño ni los ingresos del infractor— Brasil establece sanciones de hasta el dos por ciento del faturamento (facturación) de la persona jurídica, del grupo o del conglomerado en Brasil en su último ejercicio fiscal, con un tope máximo de cincuenta millones de reales por infracción (LGPD, 2018, art. 52, inc. II). Este modelo es proporcional: una empresa grande que viola los datos de salud de sus clientes enfrenta una sanción significativa en relación con sus ingresos, mientras que un profesional independiente con consulta privada enfrenta una sanción proporcional a su escala. La LFPDPPP mexicana aplica el mismo techo absoluto de UMAs independientemente del tamaño del infractor, lo que puede resultar desproporcionadamente severo para un nutriólogo independiente y relativamente leve para una empresa de salud digital con millones de usuarios.

Lo que muestra el caso brasileño no es que su ley sea perfecta, sino que tomó decisiones de diseño más coherentes: una autoridad independiente, un modelo sancionador proporcional, derechos de portabilidad desde el inicio y una base constitucional sólida. México tiene instrumentos técnicos únicos en la región —las NOMs— que Brasil no tiene, pero carece de la arquitectura institucional y de los derechos explícitos que Brasil construyó. Para NutriApp, el caso brasileño ofrece el mapa más claro de qué funcionalidades y garantías debería incorporar por diseño, aun antes de que la ley mexicana las exija formalmente.

2.2.2. Uruguay: Ley 18.331/2008

Uruguay es el caso más silencioso y más instructivo del análisis. No tiene el tamaño de Brasil ni la visibilidad internacional de Alemania, pero desde 2008 opera con un marco de protección de datos que supera a México en aspectos concretos y medibles. Lo que hace relevante a Uruguay para este caso de estudio no es su ley en abstracto,

sino una decisión específica que México todavía no ha tomado: hacer obligatoria la historia clínica electrónica para todos los prestadores de salud, públicos y privados, sin excepción.

I. La ley más alineada al estándar europeo en toda América Latina.

La Ley 18.331, promulgada el 11 de agosto de 2008 y reglamentada por el Decreto 414/009, fue construida sobre los principios del Convenio 108 del Consejo de Europa para la protección de las personas respecto al tratamiento automatizado de datos de carácter personal (Ley 18.331, 2008, Exposición de Motivos). Uruguay es el único país de América Latina que ratificó ese Convenio, en 2013, convirtiéndose en el primer Estado no europeo en adherirse al instrumento de referencia del que derivó posteriormente el GDPR europeo. Esto no es un reconocimiento simbólico: la ratificación del Convenio 108 implica que Uruguay acepta revisiones periódicas de su marco normativo por parte del Consejo de Europa y debe mantener sus estándares alineados con la evolución del derecho europeo de protección de datos. México no tiene ningún compromiso equivalente con ningún organismo internacional en esta materia.

II. La URCDP: autoridad independiente con poderes reales, incluida la clausura judicial de bases de datos.

La Unidad Reguladora y de Control de Datos Personales (URCDP) fue creada por la propia Ley 18.331 como el organismo de control independiente en materia de protección de datos personales (Ley 18.331, 2008, arts. 20 y 21). Su independencia no es solo formal: la URCDP tiene potestad para aplicar sanciones que van desde la advertencia y la multa económica hasta la suspensión del tratamiento de datos, e inclusive puede solicitar al Poder Judicial la clausura de una base de datos en los casos más graves (Decreto 414/009, 2009, art. 31). Este último instrumento no tiene equivalente en la LFPDPPP mexicana, que contempla sanciones administrativas y penales pero no la clausura judicial de sistemas de información. La existencia de ese mecanismo extremo no implica que se use frecuentemente, pero su sola disponibilidad establece un estándar de consecuencias que la autoridad mexicana actual no puede replicar. Adicionalmente, la URCDP promueve la figura del Delegado de Protección de Datos dentro de las organizaciones —un rol interno de supervisión y cumplimiento que en México no tiene equivalente normativo ni recomendación formal de la autoridad.

III. Notificación de brechas en 72 horas: más estricto que México y equi-

parable a Europa. La Ley 18.331, complementada por su Decreto Reglamentario 414/009, establece que ante una violación de seguridad que afecte datos personales, el responsable del tratamiento debe notificar tanto a la URCDP co-

mo a los titulares afectados en un plazo de setenta y dos horas desde que tuvo conocimiento del incidente (Decreto 414/009, 2009, art. 31). Este plazo es idéntico al que establece el GDPR europeo y al que la ANPD brasileña aplica como referencia. La LFPDPPP mexicana de 2025 obliga a notificar vulneraciones en su artículo 20, pero sin fijar un plazo específico ni definir los umbrales de riesgo que activan esa obligación, lo que genera ambigüedad en el cumplimiento y dificulta la comparación con estándares internacionales.

IV. Portabilidad de datos: incluida desde el diseño original de la ley. El artículo 14 de la Ley 18.331 reconoce entre los derechos del titular el de obtener sus datos en un formato estructurado y transferible (Ley 18.331, 2008, art. 14). Al igual que Brasil, Uruguay incorporó la portabilidad como derecho explícito desde la redacción original de su ley, a diferencia de México, cuya LFPDPPP contempla los derechos de Acceso, Rectificación, Cancelación y Oposición (ARCO) pero no la portabilidad como derecho autónomo. Para un paciente de nutrición, la portabilidad significa poder exigir que su expediente completo le sea entregado en un formato que otro profesional o sistema pueda leer y usar directamente, sin depender de la buena voluntad del nutriólogo anterior ni de la compatibilidad entre herramientas.

V. Historia clínica electrónica obligatoria: la decisión que México no ha tomado. Este es el punto más relevante para este caso de estudio. En 2017, Uruguay estableció mediante el Decreto 242/017 que todos los prestadores de salud —públicos y privados, sin importar su tamaño ni especialidad— están obligados a llevar una historia clínica electrónica de cada paciente, siendo responsables de su completitud y seguridad conforme a las normas legales vigentes (Decreto 242/017, 2017, art. 1°). Este mandato se complementa con la Ordenanza N° 1085/2017 del Ministerio de Salud Pública, que establece los estándares técnicos de interoperabilidad y seguridad del Sistema de Historia Clínica Electrónica Nacional (HCEN), incluyendo principios de finalidad, veracidad, completitud, reserva, información y accesibilidad (Ordenanza MSP N° 1085/2017, 2017, art. 3°). México tiene en la NOM-024-SSA3-2012 una norma técnica equivalente en rigor y detalle para los sistemas de expediente clínico electrónico, pero con una diferencia fundamental: la NOM-024 solo aplica si el profesional o establecimiento decide adoptar un sistema electrónico. Nadie está obligado a hacerlo. Un nutriólogo puede seguir llevando sus expedientes en papel o en una hoja de cálculo sin violar ninguna norma que lo obligue a usar un sistema digital. Uruguay cerró esa brecha en 2017. México, al momento de redactar este documento, no lo ha hecho. Este vacío es precisamente el espacio que NutriApp busca ocupar: no para esperar a que la ley lo exija, sino para ofrecer desde hoy el estándar que la evidencia comparada

indica que tarde o temprano será necesario.

El caso uruguayo demuestra que la solidez normativa no es función del tamaño del país ni de su presupuesto regulatorio. Con una economía significativamente menor que la mexicana y un sistema de salud más pequeño, Uruguay tomó decisiones de política pública que México aún no ha adoptado: historia clínica electrónica obligatoria, notificación de brechas con plazo definido, portabilidad de datos explícita y una autoridad con herramientas reales de sanción. Para NutriApp, Uruguay no es solo un referente normativo; es la prueba de que las decisiones que este caso de estudio propone son técnicamente viables y políticamente posibles.

2.2.3. Estados Unidos: HIPAA, HITECH y el modelo de responsabilidad compartida

Estados Unidos es el único país de este análisis que no tiene una ley federal unificada de protección de datos personales. En su lugar opera un modelo sectorial: cada industria tiene su propio marco regulatorio, y el sector salud es el que cuenta con la arquitectura más desarrollada y de mayor impacto internacional. Lo que hace relevante el caso estadounidense para este estudio no es su complejidad técnica sino una decisión de política pública que México todavía no ha tomado: en Estados Unidos, el proveedor de software que procesa datos de salud es tan responsable del cumplimiento legal como el profesional que lo usa. Esa lógica no existe en la LFPDPPP mexicana.

I. HIPAA: el piso federal obligatorio en los 50 estados, sin excepción geográfica. La Health Insurance Portability and Accountability Act de 1996 (HIPAA) establece el estándar federal mínimo de privacidad y seguridad para la información de salud identificable de las personas —denominada Protected Health Information (PHI)— en todo el territorio de Estados Unidos (Health Insurance Portability and Accountability Act [HIPAA], 1996, 45 CFR Parts 160 y 164). Toda entidad cubierta (*covered entity*) —hospitales, clínicas, laboratorios, profesionales de salud que facturan a aseguradoras, y cualquier organización que transmita PHI en formato electrónico— está obligada a cumplir la HIPAA Privacy Rule y la HIPAA Security Rule con independencia del estado en que opere. No existe ningún estado que pueda eximir a sus establecimientos de salud de cumplir HIPAA: la ley federal prevalece sobre cualquier norma estatal que ofrezca menor protección (Departamento de Salud y Servicios Humanos de EE.UU. [HHS], 2013, 45 CFR § 160.203). Lo que los estados sí pueden hacer —y muchos han hecho— es ir más lejos que HIPAA, añadiendo obligaciones adicionales por encima del piso federal. Cuando hay conflicto entre una norma estatal y HIPAA, siempre prevalece la que ofrece mayor protección al titular de los datos (HHS,

2013, 45 CFR § 160.203). Esto significa que el mapa regulatorio en salud en Estados Unidos no es un caos de cincuenta marcos distintos: es un piso federal único con capas adicionales que varían por estado.

II. **El HITECH Act: cuando el proveedor de software también responde ante la ley.**

La transformación más relevante para este caso de estudio llegó en 2009, no con una nueva ley de privacidad sino con la Health Information Technology for Economic and Clinical Health Act (HITECH Act). Antes de su promulgación, los proveedores de software y servicios tecnológicos que procesaban PHI en nombre de una covered entity tenían obligaciones contractuales pero no responsabilidad legal directa ante el gobierno federal. El HITECH Act cambió eso de manera radical: extendió las obligaciones de la HIPAA Security Rule directamente a los *business associates* —cualquier proveedor que toque PHI en nombre de una covered entity, incluyendo desarrolladores de software de expediente clínico, proveedores de nube, empresas de análisis de datos y servicios de facturación médica— convirtiéndolos en sujetos directamente responsables ante el Departamento de Salud y Servicios Humanos (Health Information Technology for Economic and Clinical Health Act [HITECH Act], 2009, § 13401). En México, la LFPDPPP establece que el responsable del tratamiento de datos es el nutriólogo o la clínica, no el proveedor del software que usa. Un desarrollador de aplicaciones de nutrición que opera en México no tiene ninguna obligación legal directa de cumplir con los estándares técnicos de la LFPDPPP: su responsabilidad termina en el contrato con el cliente. En Estados Unidos, esa misma empresa sería un business associate con responsabilidad directa ante el HHS, sujeta a auditorías, sanciones y la obligación de firmar un Business Associate Agreement con cada covered entity a la que le venda su producto.

III. **El Business Associate Agreement: el contrato que hace al ecosistema tecnológico corresponsable.**

El Business Associate Agreement (BAA) es el instrumento legal que materializa la responsabilidad compartida entre la covered entity y su proveedor tecnológico. Su firma es obligatoria en todos los casos en que un proveedor externo tenga acceso a PHI, y su ausencia constituye por sí misma una violación de HIPAA (HHS, 2013, 45 CFR § 164.308(b)). El BAA establece, entre otros elementos, qué usos puede hacer el proveedor de los datos de salud que procesa, qué medidas de seguridad debe implementar, qué debe hacer ante una brecha de seguridad y cómo debe destruir o devolver los datos al terminar el contrato. Para NutriApp, este mecanismo es un referente de diseño: aunque la ley mexicana no exige un documento equivalente, el Reglamento de la LFPDPPP establece en su artículo 51 que cuando el responsable comparte datos con un encargado, debe existir un contrato que establezca las obligaciones de este

último (RLFPDPPP, 2011, art. 51). El BAA estadounidense es la versión madura y detallada de ese principio que México tiene en la ley pero no ha traducido en un instrumento estandarizado.

IV. La capa estatal: estados que van más lejos que HIPAA en salud digital.

Varios estados han identificado vacíos en la cobertura de HIPAA —particularmente para datos de salud generados por aplicaciones móviles, dispositivos wearables y plataformas de bienestar que no califican como covered entities— y han legislado para cerrarlos. California cuenta con la California Consumer Privacy Act (CCPA) y la Confidentiality of Medical Information Act (CMIA), que juntas cubren datos de salud que no califican como PHI bajo HIPAA, incluyendo información recopilada por aplicaciones de nutrición y bienestar (California Consumer Privacy Act [CCPA], Cal. Civ. Code § 1798.100 et seq., 2018). Washington promulgó en 2023 el My Health My Data Act, vigente desde 2024, que aplica a *cualquier* empresa que procese datos de salud de consumidores con independencia de si es o no una covered entity bajo HIPAA, y exige consentimiento opt-in explícito para la mayoría de los usos de datos de salud (Washington My Health My Data Act [MHMDA], 2023, RCW 70.372). Maryland, Nevada, Connecticut y Colorado han promulgado legislación similar con distintos alcances. Al momento de redactar este documento, más de veintiséis estados tienen iniciativas de privacidad de datos de salud en distintas etapas legislativas (Inside Privacy, 2024).

V. La HIPAA Security Rule en actualización: cifrado y MFA pasarán a ser obligatorios sin excepción.

La HIPAA Security Rule original, promulgada en 2003, distinguía entre salvaguardas *required* —obligatorias sin excepción— y *addressable* —aplicables salvo que el responsable documentara una alternativa equivalente. El cifrado de datos electrónicos de salud era una salvaguarda addressable, lo que en la práctica permitía a algunas organizaciones argumentar que su alternativa era suficiente. En enero de 2025, el Departamento de Salud y Servicios Humanos publicó una propuesta de actualización de la Security Rule (NPRM 2025) que elimina esa distinción y convierte el cifrado de ePHI y la autenticación multifactor (MFA) en obligaciones absolutas sin posibilidad de justificación alternativa (HHS, 2025, HIPAA Security Rule NPRM). La regla final se espera en 2026, con un período de cumplimiento de 240 días. Este movimiento regulatorio es relevante para NutriApp porque confirma la dirección que el estándar internacional de mayor adopción en salud digital está tomando: cifrado y MFA dejan de ser opcionales. El diseño técnico de NutriApp sobre AWS incorpora ambos elementos desde el inicio, lo que significa que la plataforma no solo cumplirá con la normativa mexicana vigente sino que estará alineada con la evolución del estándar de referencia internacional.

El modelo estadounidense ilustra con claridad lo que México no tiene todavía: un mecanismo que haga al ecosistema tecnológico de la salud corresponsable del cumplimiento legal. En México, el nutriólogo responde por cómo maneja los datos de sus pacientes, pero el software que usa para hacerlo no tiene ninguna obligación legal directa. En Estados Unidos, esa separación desapareció en 2009. Mientras eso no cambie en México, la única forma de cerrar esa brecha es que el software de salud adopte voluntariamente los estándares que la ley todavía no exige. Ese es uno de los principios de diseño centrales de NutriApp.

2.2.4. Alemania: GDPR, BDSG, PDSG y el estándar de nube en salud más exigente del mundo

Si Brasil es el espejo de lo que México podría ser en América Latina, Alemania es el techo de lo que un sistema de protección de datos de salud puede llegar a ser cuando se construye con décadas de consistencia, múltiples capas normativas y una cultura institucional que trata la privacidad como un derecho fundamental irrenunciable. El caso alemán no se propone aquí como un modelo directamente replicable para México —las diferencias de contexto son demasiado grandes— sino como la referencia que permite calibrar con precisión qué tan lejos está México del estándar más exigente disponible, y qué implica ese estándar para el diseño técnico de NutriApp.

- I. **El GDPR: el marco base que Alemania aplica con más rigor que cualquier otro país de la Unión Europea.** El Reglamento General de Protección de Datos de la Unión Europea (GDPR, Reglamento UE 2016/679) entró en vigor el 25 de mayo de 2018 y es directamente aplicable en Alemania sin necesidad de transposición legislativa (Reglamento UE 2016/679 [GDPR], 2016, art. 99). Sus disposiciones para datos de salud son las más estrictas del instrumento: el artículo 9 clasifica los datos relativos a la salud como una categoría especial de datos personales cuyo tratamiento está prohibido por defecto, salvo que concurra alguna de las bases de legitimación expresamente enumeradas —entre ellas el consentimiento explícito del interesado, la necesidad para fines de atención sanitaria o la existencia de un interés público en el ámbito de la salud pública (GDPR, 2016, art. 9, párr. 2). Las sanciones por infracción de esta categoría pueden alcanzar los veinte millones de euros o el cuatro por ciento de la facturación global anual de la empresa infractora, la cifra que resulte más elevada (GDPR, 2016, art. 83, párr. 5). Alemania no solo aplica el GDPR: es el país de la Unión Europea con el mayor número de autoridades de supervisión —una por cada uno de sus dieciséis estados federados (*Länder*), más el Comisionado Federal para la Protección de Datos e Información (BfDI) para los organismos federales— coordinadas a través

de la Conferencia de Protección de Datos (DSK), que publica orientaciones y coordina la aplicación uniforme del reglamento en todo el territorio nacional.

II. El BDSG: la capa nacional que refuerza el GDPR con sanciones penales propias. Alemania ejerció las cláusulas de apertura del GDPR para promulgar su propia ley federal de protección de datos, la Bundesdatenschutzgesetz (BDSG), que entró en vigor simultáneamente con el GDPR el 25 de mayo de 2018 (Bundesdatenschutzgesetz [BDSG], 2018). El BDSG complementa el reglamento europeo en áreas donde el GDPR delega a los estados miembros la capacidad de legislar con mayor especificidad: protección de datos en el contexto laboral, facultades de las autoridades supervisoras y, de manera particularmente relevante para el sector salud, sanciones penales para violaciones comerciales de datos personales. La sección 42 del BDSG tipifica como delito penal la divulgación no autorizada de datos personales con ánimo de enriquecimiento propio o de terceros, con penas de prisión de hasta tres años o multa (BDSG, 2018, § 42). Esto significa que en Alemania, un profesional de la salud o un proveedor de software que comercialice datos de pacientes sin autorización no solo enfrenta sanciones administrativas del GDPR sino también responsabilidad penal específica del BDSG. La LFPDPPP mexicana contempla sanciones penales en sus artículos 62 al 64, pero limitadas a conductas que involucren engaño o ánimo de lucro directo; el CPF amplía esa responsabilidad a través de sus artículos 210 y 211 para profesionistas, como se analizó en la sección 2.1.4 de este documento. El BDSG alemán es más específico y más integrado con el marco de protección de datos en su conjunto.

III. El PDSG: la ley que digitalizó el sistema de salud alemán y protegió los datos en ese proceso. En 2020, Alemania promulgó la Patientendatenschutzgesetz (PDSG), la Ley de Protección de Datos de Pacientes, que regula específicamente el procesamiento digital de información de salud a través del expediente electrónico del paciente (*elektronische Patientenakte*, ePA), las recetas electrónicas y las derivaciones digitales (Patientendatenschutzgesetz [PDSG], 2020). El PDSG aplica a todas las organizaciones de salud que utilizan la infraestructura telemática alemana —hospitales, consultorios médicos, farmacias, aseguradoras de salud— con independencia de su tamaño. A partir de 2021, las aseguradoras de salud públicas quedaron obligadas a ofrecer a sus asegurados un expediente electrónico de paciente, y desde 2024 ese expediente se activa de forma predeterminada para todos los asegurados salvo que estos opten explícitamente por no tenerlo (PDSG, 2020, en relación con SGB V § 341). El PDSG no reemplaza al GDPR ni al BDSG: los tres instrumentos coexisten y se aplican de forma acumulativa. Para un software de salud que opere en Alemania, cumplir el PDSG es una condición necesaria pero no suficiente: también debe cumplir el GDPR y

el BDSG de manera simultánea. México no tiene ningún equivalente al PDSG: la NOM-024-SSA3-2012 es el instrumento técnico más cercano en especificidad, pero no tiene el rango de ley ni la integración con el sistema nacional de salud que el PDSG alemán establece.

IV. SGB V §393: la regulación de nube en salud más exigente del mundo y su relevancia directa para NutriApp. En julio de 2024, Alemania promulgó la Digitalgesetz (Ley Digital), que incorporó el artículo 393 al Quinto Libro del Código de Seguridad Social (SGB V), estableciendo requisitos específicos y obligatorios para el uso de servicios de cómputo en la nube en el sistema de salud alemán (SGB V § 393, Digitalgesetz, 2024). Sus disposiciones son las más restrictivas del mundo para este sector y tienen implicaciones directas para cualquier arquitectura de software de salud:

- Los datos de salud y los datos sociales solo pueden procesarse en servicios de nube ubicados dentro de Alemania, dentro de otro Estado miembro de la Unión Europea o del Espacio Económico Europeo, o en un tercer país que cuente con una decisión de adecuación de la Comisión Europea (SGB V § 393, párr. 1). Esto excluye, por ejemplo, el uso de servidores ubicados en Estados Unidos salvo que el proveedor cuente con esa decisión de adecuación, que actualmente no existe de forma general para EE.UU.
- La ley no reconoce las Cláusulas Contractuales Tipo (Standard Contractual Clauses) como garantía suficiente para la transferencia de datos de salud a terceros países sin decisión de adecuación. Esta es una postura más restrictiva que el propio GDPR, que sí acepta las SCCs como mecanismo de transferencia internacional (SGB V § 393, párr. 1).
- Todo proveedor de servicios de nube o software como servicio (SaaS) que procese datos de salud en el sistema alemán debe contar con una certificación vigente bajo el catálogo C5 (Cloud Computing Compliance Criteria Catalogue) del Bundesamt für Sicherheit in der Informationstechnik (BSI), la Oficina Federal de Seguridad en Tecnología de la Información de Alemania. A partir de julio de 2025, se requiere el certificado C5 Tipo 2, que implica una auditoría independiente y periódica de los controles de seguridad (SGB V § 393, párr. 3).

La relevancia de esta regulación para NutriApp no es que la plataforma opere en Alemania, sino que Amazon Web Services —la infraestructura seleccionada para NutriApp— cuenta con certificación C5 BSI en su región de Frankfurt (EU-West) y opera centros de datos dentro de la Unión Europea que cumplen con los

requisitos de localización del SGB V § 393. Esto significa que la arquitectura de NutriApp sobre AWS no es una decisión arbitraria: es una elección de infraestructura que cumple con el estándar de nube en salud más exigente del mundo sin requerir modificaciones de diseño adicionales. El Reglamento de la LFPDPPP mexicana, en su artículo 52, permite expresamente el uso de servicios de cómputo en la nube siempre que el proveedor ofrezca niveles de protección equivalentes a los que exige la ley mexicana (RLFPDPPP, 2011, art. 52). AWS con certificación C5 BSI supera con amplitud ese umbral.

V. Lo que varía por estado alemán: autoridades supervisoras y leyes sectoriales de salud. A diferencia de lo que ocurre con el GDPR, el BDSG y el PDSG —que son federales y aplican de forma uniforme en los dieciséis estados— Alemania tiene también una capa de regulación estatal que es relevante para el sector salud. Cada *Länder* tiene su propia autoridad supervisora de protección de datos con competencia sobre los organismos públicos y las empresas privadas de ese territorio, y puede publicar orientaciones o recomendaciones adicionales que complementan las del BfDI federal. Adicionalmente, cada estado tiene sus propias leyes hospitalarias, leyes de salud mental (como la PsychKG de Berlín o la BayMRVG de Baviera) y, en el caso de hospitales de patrocinio religioso, normativa eclesiástica propia que puede establecer restricciones adicionales al tratamiento de datos. Para los efectos de este caso de estudio, estas capas estatales son matices que no alteran el argumento central: la regulación federal alemana establece el estándar más alto disponible, y ese es el nivel de referencia relevante para evaluar el diseño de NutriApp.

El caso alemán no es un modelo que México pueda ni deba replicar íntegramente: sus condiciones institucionales, su integración europea y su historia regulatoria en protección de datos son singulares. Lo que sí es replicable —y lo que este caso de estudio propone como referencia de diseño— es la lógica subyacente del SGB V § 393: cuando los datos de salud se procesan en la nube, el proveedor de esa nube debe poder demostrar, mediante certificación independiente, que cumple con estándares técnicos verificables. AWS lo hace. NutriApp lo aprovecha. México no lo exige todavía, pero elegir una infraestructura que ya cumple el estándar más estricto del mundo es una decisión de diseño que tiene consecuencias directas sobre la confianza que el sistema puede generar en los pacientes y en los propios profesionales que lo usen.

2.2.5. Cuadro comparativo regional

El cuadro siguiente sintetiza los nueve criterios más relevantes para este caso de estudio en los cinco marcos normativos analizados. Su función no es repetir el análisis narrativo

de las subsecciones anteriores sino ofrecer una referencia visual de consulta rápida que permita identificar de un solo vistazo en qué dimensiones México se encuentra por debajo, a la par o por encima de cada uno de los sistemas comparados. Los criterios se seleccionaron por su relevancia directa para el diseño de NutriApp y para la práctica del nutriólogo de consulta privada. Por razones de legibilidad, el cuadro se presenta en dos partes: la primera concentra los criterios legales e institucionales; la segunda, los criterios técnicos y sancionadores.

Tabla 1: Comparativo de marcos normativos en protección de datos de salud — Parte 1: criterios legales e institucionales.

Criterio	México	Brasil	Uruguay	EE.UU.	Alemania
1. Ley principal vigente	LFPDPPP (2025). Reemplaza a la ley de 2010. Principios y derechos ARCO se mantienen con ajustes en sanciones y autoridad.	Lei Geral de Proteção de Dados — LGPD (Lei 13.709/2018). Vigente desde septiembre de 2020. Diseñada con el GDPR europeo como modelo explícito.	Ley 18.331/2008 y Decreto Reglamentario 414/009. La ley más antigua de la región aún vigente sin sustitución. Alineada al Convenio 108 del Consejo de Europa desde su origen.	No existe ley federal unificada de protección de datos. El sector salud se rige por HIPAA (1996) complementada por el HITECH Act (2009). Cada estado puede añadir capas adicionales.	GDPR (Reglamento UE 2016/679) como base directamente aplicable, complementado por el BDSG (2018) y el PDSG (2020) para el sector salud específicamente.
2. Autoridad reguladora	Secretaría Anticorrupción y Buen Gobierno (SABG). Dependiente del Ejecutivo Federal desde marzo 2025. Reemplazó al INAI, que era autónomo constitucionalmente desde 2014.	Autoridade Nacional de Proteção de Dados (ANPD). Independiente del Ejecutivo. Directores con mandatos fijos de cuatro años no removibles por razones políticas.	Unidad Reguladora y de Control de Datos Personales (URCDP). Independiente. Con potestad de suspender tratamientos y solicitar clausura judicial de bases de datos en casos graves.	Departamento de Salud y Servicios Humanos (HHS) a nivel federal, a través de su Oficina de Derechos Civiles (OCR). Cada estado tiene además su propia autoridad de protección de datos.	Comisionado Federal para la Protección de Datos e Información (BfDI) para organismos federales. Cada uno de los 16 Länder tiene su propia autoridad supervisora estatal. Coordinadas por la Conferencia

Tabla 2: Comparativo de marcos normativos en protección de datos de salud — Parte 2: criterios técnicos y sancionadores.

Criterio	México	Brasil	Uruguay	EE.UU.	Alemania
6. Portabilidad de datos	No contemplada explícitamente en la LFPDPPP vigente. Los derechos ARCO incluyen acceso y cancelación, pero no el derecho a transferir datos a otro responsable en formato utilizable.	Sí. Art. 18, inc. V LGPD. El titular puede solicitar la portabilidad de sus datos a otro proveedor de servicio o producto mediante solicitud expresa, observando secretos comerciales e industriales.	Sí. Art. 14 Ley 18.331. El titular tiene derecho a obtener sus datos en formato estructurado y transferible. Incluido desde la redacción original de la ley en 2008.	Parcial. HIPAA garantiza el derecho de acceso y copia del expediente en formato electrónico (45 CFR § 164.524). La portabilidad amplia — transferencia directa a otro proveedor— está contemplada en la CCPA de California pero no en HIPAA federal.	Sí. Art. 20 GDPR. El titular tiene derecho a recibir sus datos en formato estructurado, de uso común y lectura mecánica, y a transmitirlos a otro responsable sin que el primero lo impida.
7. Sanciones máximas	Hasta 320,000 veces la UMA (~\$36.2 mdp) por infracción grave; duplicables cuando involucran datos sensibles de salud	Hasta el 2 % del faturamento (facturación) del grupo en Brasil en el último ejercicio fiscal, con tope de 50 millones de reales por	Amonestación, multa económica cuyo monto varía según la gravedad, suspensión del tratamiento de datos por hasta 33 días y clausura de la base de	Multas civiles del HHS de hasta USD 1.9 millones por categoría de violación por año calendario. Sanciones penales bajo HITECH Act: hasta	Hasta 20 millones de euros o el 4 % de la facturación global anual del grupo, la cifra que resulte más elevada (art. 83, párr. 5 GDPR). Sanciones

Lo que el cuadro anterior revela no es que México esté en el peor lugar del análisis en todas las dimensiones: en el criterio de marco técnico obligatorio para software de salud, las NOMs mexicanas son el instrumento más específico y el único de la región que establece requerimientos técnicos concretos de cifrado, autenticación y trazabilidad en una sola norma. El problema no es la norma; es que nadie está obligado a usarla. En portabilidad y en notificación de brechas con plazo definido, México está por debajo de Brasil, Uruguay y Alemania. En independencia de la autoridad reguladora, México retrocedió en 2025 respecto a todos los países del comparativo. Y en la dimensión más crítica para el argumento central de este caso de estudio —la responsabilidad del software de salud como sujeto obligado ante la ley— México no tiene ningún mecanismo equivalente al Business Associate Agreement estadounidense ni al esquema de certificación de nube del SGB V § 393 alemán. NutriApp no puede cambiar el marco legal mexicano, pero puede adoptar por diseño los estándares que ese marco todavía no exige.

2.3. Análisis crítico de la ley mexicana

El recorrido por los marcos normativos de Brasil, Uruguay, Estados Unidos y Alemania no tiene sentido si no se traduce en una evaluación concreta de la posición de México. Esta subsección hace ese ejercicio: identifica lo que la LFPDPPP y su ecosistema normativo tienen de sólido —porque sí hay elementos que México construyó mejor que otros países de la región— y lo que el comparativo reveló como ausencias reales con consecuencias prácticas para el nutriólogo de consulta privada y para el diseño de NutriApp. El objetivo no es emitir un veredicto sobre la ley sino calibrar con precisión qué problemas puede resolver una solución tecnológica y cuáles requieren cambios que están fuera del alcance de este caso de estudio.

2.3.1. Fortalezas del marco normativo mexicano

El análisis comparativo reveló algo que no siempre se reconoce en los debates sobre protección de datos en México: el país tiene instrumentos normativos que no existen en ningún otro país de la comparativa y que, bien aplicados, establecerían un estándar técnico-legal superior al de Brasil, Uruguay y, en aspectos específicos, al de Estados Unidos. El problema no es la ausencia de herramientas sino su subutilización sistemática.

- I. Las Normas Oficiales Mexicanas: el único marco técnico obligatorio y específico para el expediente clínico electrónico en toda la región.** Ningún país del análisis comparativo tiene un equivalente a la combinación NOM-

004-SSA3-2012 y NOM-024-SSA3-2012. Brasil opera con resoluciones gremiales del CFM dispersas por tipo de servicio, sin una norma única que establezca requerimientos técnicos unificados para todo sistema de expediente clínico electrónico. Uruguay tiene el Decreto 242/017 y la Ordenanza MSP 1085/2017, que obligan a adoptar la historia clínica electrónica pero no especifican con el mismo nivel de detalle técnico los requisitos de cifrado, autenticación y trazabilidad que la NOM-024 establece. Estados Unidos tiene la HIPAA Security Rule, que es comparable en rigor pero de alcance sectorial y sin la especificidad diagnóstica del expediente clínico que la NOM-004 proporciona. Alemania tiene el PDSG y el SGB V § 393, pero estos instrumentos regulan el ecosistema digital de salud en su conjunto, no el expediente clínico como documento clínico-legal en sí mismo. La NOM-004 establece con precisión qué debe contener un expediente de nutriología, cómo debe conservarse y por cuánto tiempo, y la NOM-024 traduce esas obligaciones en requerimientos técnicos verificables para cualquier sistema electrónico que lo gestione. Ese nivel de especificidad clínica integrada con requerimientos técnicos de seguridad es una fortaleza singular del marco mexicano que ningún otro país de la comparativa ha logrado en un solo instrumento normativo.

II. Doble anclaje constitucional: la protección de datos como derecho fundamental en dos artículos independientes. México reconoció la protección de datos personales como derecho fundamental en la Constitución en dos momentos distintos y con dos enfoques complementarios. La reforma de 2007 al artículo 6° estableció el derecho de acceso a la información y la protección de datos en el ámbito gubernamental. La reforma de 2009 al artículo 16 extendió ese reconocimiento a todos los particulares, estableciendo el derecho de toda persona a la protección de sus datos personales y los derechos ARCO como garantías constitucionales (CPEUM, 1917/2024, arts. 6° y 16). Este doble anclaje constitucional es más robusto que el de Uruguay, cuya Ley 18.331 tiene rango legal ordinario, y comparable al de Brasil, que elevó la protección de datos a derecho fundamental mediante la Emenda Constitucional n° 115 en 2022 —trece años después de que México lo hiciera. En la Unión Europea, el GDPR tiene rango reglamentario europeo y se apoya en la Carta de Derechos Fundamentales de la UE, no en las constituciones nacionales de cada Estado miembro. El anclaje constitucional mexicano es, en términos de jerarquía normativa, una fortaleza real que protege el derecho frente a cambios legislativos ordinarios.

III. Doble obligación de consentimiento: la intersección LFPDPPP y Ley General de Salud como el estándar más exigente del análisis para el sector salud. Ningún otro país del comparativo establece para el sector salud una doble obligación de consentimiento escrito proveniente de dos leyes indepen-

dientes con autoridades sancionadoras distintas. En México, el nutriólogo que no cuenta con el consentimiento firmado de su paciente está en incumplimiento simultáneo de la LFPDPPP (art. 8) y de la Ley General de Salud (art. 51 Bis 2°), lo que activa dos vías sancionadoras paralelas: la administrativa de la SABG por la LFPDPPP y la sanitaria de la COFEPRIS por la LGS. Brasil exige consentimiento bajo la LGPD, pero no tiene una ley de salud que duplique esa obligación de forma independiente. Uruguay exige consentimiento bajo la Ley 18.331, pero sin el refuerzo de una ley sanitaria equivalente a la LGS mexicana. Estados Unidos exige autorización escrita bajo HIPAA, pero no tiene una segunda ley que genere responsabilidad simultánea ante una autoridad distinta por el mismo acto. Este doble anclaje legal del consentimiento —que en 2.1.3 se describió como una aparente redundancia— es en realidad una fortaleza estructural que hace al sistema mexicano más difícil de evadir en el sector salud: no basta con cumplir una sola ley, hay que cumplir las dos.

IV. El Reglamento de 2011: el instrumento técnico que adelantó soluciones que otras leyes tardaron años en incorporar. El Reglamento de la LFPDPPP, publicado en diciembre de 2011, fue en su momento uno de los instrumentos reglamentarios más detallados de América Latina en materia de protección de datos. Sus artículos 57 y 61 establecieron desde entonces obligaciones que países como Brasil apenas incorporaron con la LGPD en 2018: medidas de seguridad aplicables con independencia del sistema de tratamiento (art. 57), inventario de datos, análisis de riesgos y análisis de brecha como procedimientos formales obligatorios (art. 61). El artículo 52 del Reglamento fue también uno de los primeros instrumentos legales en América Latina en reconocer expresamente el uso de servicios de cómputo en la nube como mecanismo legítimo de tratamiento de datos, estableciendo como condición que el proveedor ofrezca niveles de protección equivalentes a los de la ley mexicana (RLFPDPPP, 2011, art. 52). Ese artículo es el fundamento legal que respalda el uso de Amazon Web Services como infraestructura de NutriApp, y fue redactado catorce años antes de que Alemania promulgara el SGB V § 393 para regular el mismo tema con mayor especificidad.

Lo que estas fortalezas tienen en común es que ninguna es visible para el nutriólogo promedio. Las NOMs existen pero nadie las aplica en consultorios privados. El doble anclaje constitucional existe pero no se traduce en capacitación ni en requisitos de cumplimiento para el gremio. La doble obligación de consentimiento existe pero la mayoría de los consultorios opera sin un solo documento firmado. El Reglamento existe pero sus obligaciones de inventario y análisis de riesgo son desconocidas para quien no tiene asesoría legal especializada. La fortaleza del marco normativo mexicano es real,

pero es una fortaleza en papel. Su conversión en práctica cotidiana es precisamente el problema que este caso de estudio busca atender.

2.3.2. Debilidades: la ambigüedad técnica y las ausencias estructurales

Si las fortalezas del marco mexicano son reales pero invisibles, sus debilidades son visibles pero poco discutidas. El análisis comparativo de la sección anterior permite identificarlas con precisión: no como fallas de diseño teóricas sino como ausencias concretas que tienen consecuencias medibles para el nutriólogo que recibe una queja de un paciente, para el desarrollador de software que quiere saber cuáles son sus obligaciones legales y para el paciente que quiere saber si sus datos de salud están protegidos.

- I. **La portabilidad de datos no existe: un derecho que México no ha reconocido explícitamente.** Brasil la incorporó en la LGPD desde 2018. Uruguay la tiene desde la Ley 18.331 de 2008. El GDPR europeo la reconoce en su artículo 20. La LFPDPPP mexicana de 2025 contempla los derechos ARCO —Acceso, Rectificación, Cancelación y Oposición— pero no la portabilidad como derecho autónomo. Para el paciente de un nutriólogo, esto significa que puede solicitar una copia de su expediente (derecho de acceso) y puede exigir que lo eliminen (derecho de cancelación), pero no puede exigir que su expediente le sea entregado en un formato estructurado y transferible que otro profesional o sistema pueda usar directamente. La diferencia entre acceso y portabilidad no es semántica: el acceso da una copia, la portabilidad da interoperabilidad. En un sector donde los pacientes cambian de nutriólogo, de ciudad o de plataforma, la ausencia de portabilidad explícita fragmenta la continuidad del cuidado y concentra el historial clínico en el profesional que lo generó, no en el paciente al que pertenece.
- II. **La notificación de brechas no tiene plazo: una obligación sin dientes operativos.** El artículo 20 de la LFPDPPP 2025 obliga a notificar las vulneraciones de seguridad que afecten significativamente los derechos de los titulares, pero no establece un plazo concreto para hacerlo. Brasil tiene 72 horas como referencia de la ANPD. Uruguay tiene 72 horas por decreto. El GDPR europeo tiene 72 horas en su artículo 33. La HIPAA Breach Notification Rule tiene 60 días. México no tiene ninguno. Esta ambigüedad tiene consecuencias prácticas: sin un plazo definido, no hay criterio claro para determinar si una notificación fue oportuna o tardía, lo que dificulta la sanción del incumplimiento y desincentiva la notificación proactiva. Para el nutriólogo que sufre una brecha de seguridad —un equipo robado con expedientes sin cifrar, un acceso no autorizado a una hoja de cálculo compartida— la ausencia de un plazo definido genera incertidumbre sobre cuándo y cómo debe actuar, y para el paciente afectado significa que no

hay garantía de ser informado en un tiempo razonable.

III. La autoridad reguladora perdió su independencia en 2025: el retroceso institucional más significativo del período analizado. Entre 2014 y 2025, México operó con el INAI como organismo constitucional autónomo con independencia real del Ejecutivo, equiparable en diseño institucional a la ANPD brasileña y a la URCDP uruguaya. La extinción del INAI en marzo de 2025 y la transferencia de sus funciones a la Secretaría Anticorrupción y Buen Gobierno —un organismo que depende directamente del Ejecutivo Federal— representa el retroceso más significativo del marco normativo mexicano en el período analizado. Ningún otro país del comparativo ha tomado una decisión equivalente: Brasil mantiene la ANPD independiente, Uruguay mantiene la URCDP independiente, Estados Unidos mantiene el HHS como organismo federal con autonomía técnica, y Alemania opera con dieciséis autoridades supervisoras estatales más el BfDI federal, ninguna de las cuales depende del gobierno de turno. Las implicaciones para el nutriólogo son concretas: la autoridad ante la que debe responder si un paciente presenta una queja es ahora parte del Ejecutivo que, en teoría, esa misma dependencia debería vigilar. La percepción de imparcialidad en la resolución de conflictos entre particulares y la confianza en el sistema se ven afectadas por este cambio estructural independientemente de la competencia técnica de los funcionarios que lo integren.

IV. Las NOMs son opcionales de facto: la norma técnica más específica de la región no obliga a nadie a adoptarla. La NOM-024-SSA3-2012 establece requerimientos técnicos de cifrado, autenticación y trazabilidad que ningún otro país de la comparativa tiene en un solo instrumento obligatorio. Pero esa obligatoriedad tiene un límite crítico: aplica solo si el profesional o establecimiento decide adoptar un sistema de expediente clínico electrónico. Nadie está obligado a hacerlo. Un nutriólogo puede llevar sus expedientes en papel, en una hoja de cálculo o en una aplicación cualquiera sin violar ninguna norma que lo obligue a usar un sistema que cumpla con la NOM-024. Uruguay cerró esta brecha en 2017 con el Decreto 242/017, que hace la historia clínica electrónica obligatoria para todos los prestadores sin excepción. Colombia la está cerrando con la Ley 2015/2020 y la Resolución 1888/2025. México tiene la norma técnica más detallada de la región pero no ha tomado la decisión política de hacerla mandatoria. Ese es el vacío más específico que NutriApp busca ocupar: no esperar a que la ley lo exija, sino ofrecer desde hoy el estándar que la evidencia comparada indica que tarde o temprano será necesario cumplir.

V. El proveedor de software no es sujeto obligado: la ausencia más crítica

para el ecosistema digital de salud. En Estados Unidos, el HITECH Act de 2009 convirtió a los business associates —proveedores de software que procesan datos de salud— en sujetos directamente responsables del cumplimiento de la HIPAA Security Rule ante el HHS. En Alemania, el SGB V § 393 obliga a los proveedores de nube que procesan datos de salud a contar con certificación C5 BSI independientemente de quién sea su cliente. En México, la LFPDPPP establece que el responsable del tratamiento es el nutriólogo o el establecimiento que contrata el software, no el desarrollador que lo crea ni el proveedor de nube que lo hospeda. El Reglamento de la LFPDPPP establece en su artículo 51 que la relación entre responsable y encargado debe formalizarse en un contrato, pero ese contrato no tiene un formato estandarizado ni obligaciones mínimas definidas equivalentes al Business Associate Agreement estadounidense. Esto significa que cualquier desarrollador puede crear una aplicación de nutrición en México, almacenar los expedientes de miles de pacientes en un servidor sin cifrado, sin autenticación robusta y sin registros de acceso, y no violar ninguna ley directamente: la responsabilidad legal recae sobre el nutriólogo que contrató la aplicación, no sobre quien la desarrolló. Esta asimetría de responsabilidades desincentiva la inversión en seguridad por parte de los desarrolladores y deja al nutriólogo en una posición de vulnerabilidad legal que no controla completamente.

- VI. **Sin figura de Delegado de Protección de Datos: la ausencia de un responsable interno de cumplimiento.** El GDPR europeo exige la designación de un Data Protection Officer (DPO) para organizaciones que traten datos de salud a gran escala (GDPR, 2016, art. 37). Uruguay promueve la figura del Delegado de Protección de Datos como mecanismo interno de supervisión y cumplimiento a través de la URCDP. Brasil contempla la figura del Encarregado de Proteção de Dados en el artículo 41 de la LGPD como obligación para todos los controladores. La LFPDPPP mexicana no establece ninguna figura equivalente ni para el sector salud ni para ningún otro sector. Esto significa que en un consultorio de nutrición en México no hay ninguna persona formalmente designada para supervisar el cumplimiento de las obligaciones de protección de datos, responder solicitudes ARCO, gestionar incidentes de seguridad o mantener el inventario de datos que el artículo 61 del Reglamento exige. La ausencia de esta figura no es solo un vacío normativo: es una ausencia de accountability interno que hace que el cumplimiento dependa de la iniciativa individual del nutriólogo en lugar de estar institucionalizado en el funcionamiento ordinario del consultorio.

Lo que estas debilidades tienen en común es que ninguna requiere una reforma constitucional para resolverse: la portabilidad puede incorporarse en un decreto o reglamento; el plazo de notificación de brechas puede establecerse en una circular de la SABG; la

figura del encargado de cumplimiento puede promoverse sin necesidad de reforma legal. Lo que sí requieren es voluntad institucional y una autoridad con la independencia y la capacidad técnica para impulsarlas. Mientras esas condiciones no estén presentes, la brecha entre el estándar que las NOMs establecen en papel y la práctica cotidiana de miles de consultorios en México seguirá siendo el problema que este caso de estudio documenta y que NutriApp busca atender desde el diseño.

2.4. Traducción de la ley a requerimientos de software: Privacy by Design

Después de analizar qué exige la ley mexicana, qué hacen mejor otros países y en qué puntos el marco normativo mexicano tiene vacíos reales, la pregunta que cierra este capítulo es práctica: ¿qué significa todo eso en términos de decisiones de diseño de software? La respuesta a esa pregunta tiene un nombre en la literatura de ingeniería de privacidad: Privacy by Design. Esta subsección explica qué es ese concepto, por qué la LFPDPPP lo exige implícitamente aunque no lo nombre, y cómo cada obligación legal identificada en las secciones anteriores se traduce en un requerimiento técnico concreto de NutriApp. La tabla de trazabilidad que cierra la subsección es el puente entre el marco normativo de este capítulo y el diseño de la solución que se desarrolla en el capítulo 6.

2.4.1. Privacy by Design: el concepto y su relación con la LFPDPPP

Privacy by Design es un enfoque de ingeniería de sistemas formulado por Ann Cavoukian en 1995 mientras se desempeñaba como Comisionada de Información y Privacidad de la provincia de Ontario, Canadá (Cavoukian, 2009). Su premisa central es que la privacidad no puede ser un requisito que se agrega a un sistema después de que este ha sido diseñado y construido: debe estar integrada en la arquitectura del sistema desde su concepción, como una condición de funcionamiento y no como una característica opcional. En 2010, la Asamblea Internacional de Comisionados de Protección de Datos y Privacidad adoptó Privacy by Design como estándar internacional, y en 2018 el GDPR europeo lo incorporó como obligación legal explícita en su artículo 25, bajo la denominación de *protección de datos desde el diseño y por defecto* (GDPR, 2016, art. 25).

- I. Los siete principios de Privacy by Design y su correspondencia con la LFPDPPP.** Cavoukian definió siete principios fundacionales que articulan el enfoque de Privacy by Design (Cavoukian, 2009). Cada uno de ellos tiene una

correspondencia directa con obligaciones ya establecidas en la LFPDPPP y su Reglamento, lo que significa que México exige Privacy by Design implícitamente aunque no lo nombre de esa manera:

- **Proactivo, no reactivo; preventivo, no correctivo.** La privacidad debe anticiparse antes de que ocurra una violación, no gestionarse después. Correspondencia en la LFPDPPP: artículo 13 (responsabilidad de adoptar medidas necesarias y suficientes) y Reglamento art. 61 (análisis de riesgos y análisis de brecha como procesos obligatorios previos al tratamiento).
- **Privacidad como configuración predeterminada.** El sistema debe entregar el máximo de privacidad de forma automática, sin que el usuario tenga que hacer nada para activarla. Correspondencia en la LFPDPPP: artículo 5 (principio de proporcionalidad — solo los datos mínimos necesarios para la finalidad declarada).
- **Privacidad incrustada en el diseño.** La privacidad es parte integral de la arquitectura del sistema, no un complemento añadido. Correspondencia en el Reglamento LFPDPPP: artículo 57 (medidas de seguridad con independencia del sistema de tratamiento — aplica igual a software especializado que a hoja de cálculo).
- **Funcionalidad plena: suma positiva, no de cero.** La privacidad no debe sacrificarse por funcionalidad ni viceversa. Ambas son alcanzables simultáneamente. Correspondencia en la LFPDPPP: artículo 5 (principio de calidad — los datos deben ser exactos, completos y actualizados para cumplir su finalidad).
- **Seguridad de extremo a extremo durante todo el ciclo de vida.** La protección de los datos debe mantenerse desde su recolección hasta su eliminación. Correspondencia en la NOM-004-SSA3-2012: conservación del expediente clínico por un mínimo de cinco años con confidencialidad durante todo ese período.
- **Visibilidad y transparencia.** El sistema debe ser verificable: sus componentes deben operar de acuerdo con lo prometido al titular. Correspondencia en la LFPDPPP: artículo 15 (aviso de privacidad como obligación previa al tratamiento) y artículo 5 (principio de información).
- **Respeto por la privacidad del usuario.** El diseño debe estar centrado en los intereses del titular de los datos, no en los del responsable del tratamiento. Correspondencia en la LFPDPPP: artículos 28 al 35 (derechos

ARCO como mecanismo de control del titular sobre sus propios datos).

II. **El Reglamento de la LFPDPPP como mandato implícito de Privacy by Design.**

El artículo 61 del Reglamento de la LFPDPPP establece que el responsable del tratamiento debe elaborar un inventario de datos y sistemas, realizar un análisis de riesgos identificando las amenazas y vulnerabilidades a las que están expuestos los datos, y ejecutar un análisis de brecha para determinar las medidas de seguridad faltantes en comparación con el estándar aplicable (RLFPDPPP, 2011, art. 61). Este proceso es exactamente el ciclo metodológico de Privacy by Design aplicado al contexto legal mexicano: identificar qué datos se tienen, evaluar qué riesgos enfrentan y diseñar el sistema para eliminar o mitigar esos riesgos desde el inicio. La diferencia entre el mandato del Reglamento y la práctica cotidiana de los consultorios de nutrición es que ningún nutriólogo independiente ha sido capacitado para ejecutar ese proceso ni cuenta con las herramientas para hacerlo. NutriApp no exige que el nutriólogo lo haga: lo implementa por diseño, de modo que el cumplimiento de esos artículos sea una consecuencia automática de usar la plataforma, no una responsabilidad adicional del profesional.

III. **Por qué una hoja de cálculo no puede cumplir Privacy by Design: no es una limitación de intención sino de arquitectura.**

Una hoja de cálculo convencional —con o sin contraseña de acceso— es estructuralmente incompatible con los siete principios de Privacy by Design y con las obligaciones técnicas de la LFPDPPP, el Reglamento y las NOMs, por razones que no dependen de la buena voluntad del nutriólogo que la usa. No puede implementar autenticación diferenciada por usuario —cualquiera que conozca la contraseña del archivo tiene acceso total a todos los expedientes—, lo que viola el principio de privacidad como configuración predeterminada y el requerimiento de autenticación de la NOM-024. No genera registros de auditoría que documenten quién accedió a qué expediente y cuándo, lo que viola el requerimiento de trazabilidad del artículo 57 del Reglamento y de la NOM-024. No permite implementar cifrado de extremo a extremo sin herramientas externas que rompen el flujo de trabajo clínico. No tiene mecanismo para gestionar solicitudes ARCO con registro de resolución y plazo verificable. No puede segregar datos por nivel de sensibilidad ni aplicar políticas de retención diferenciadas. Estas no son limitaciones que se resuelvan con una versión más nueva de la hoja de cálculo: son consecuencias de la arquitectura fundamental de ese tipo de herramienta, que fue diseñada para el análisis de datos numéricos, no para el manejo de información clínica sensible bajo un marco legal de protección de datos.

2.4.2. De artículo legal a requerimiento técnico: tabla de trazabilidad normativa

La tabla siguiente establece la trazabilidad directa entre cada obligación legal identificada en este capítulo y el requerimiento técnico correspondiente en NutriApp. Su función es doble: para el lector de este documento, es la demostración de que cada decisión de diseño de la plataforma tiene un fundamento normativo verificable; para el desarrollo del sistema, es el documento de referencia que conecta el marco legal con la arquitectura técnica descrita en el capítulo 6. Por razones de legibilidad, la tabla se presenta en dos partes.

Tabla 3: Trazabilidad normativa: de obligación legal a requerimiento técnico en NutriApp — Parte 1: LFPDPPP y Reglamento.

Obligación legal	Fuente normativa	Requerimiento técnico en NutriApp
Consentimiento expreso por escrito para datos de salud	LFPDPPP 2025, art. 8; LGS, art. 51 Bis 2°	Módulo de consentimiento digital con firma electrónica del paciente, registro inmutable en el expediente y fecha de otorgamiento verificable. El consentimiento debe poder revocarse desde el mismo módulo con registro de la revocación.
Aviso de privacidad previo al tratamiento	LFPDPPP 2025, art. 15	Aviso de privacidad generado automáticamente al crear cada expediente, con registro de que fue presentado al titular antes del primer tratamiento de datos. Versión vigente del aviso siempre accesible desde el perfil del paciente.
Medidas de seguridad técnicas y administrativas	LFPDPPP 2025, art. 18; RLFPDPPP 2011, art. 57	Cifrado de datos en reposo (AES-256) y en tránsito (TLS 1.2 como mínimo). Controles de acceso basados en roles (RBAC). Separación de entornos de desarrollo y producción. Revisión periódica de controles de seguridad documentada.
Autenticación verificable de usuarios	NOM-024-SSA3-2012, requisito funcional de autenticación de usuarios antes de permitir acceso a la información	Autenticación multifactor (MFA) obligatoria para acceso al sistema. Gestión de identidades a través de Amazon Cognito. Sesiones con tiempo de expiración configurable según rol del usuario. Registro de cada inicio de sesión exitoso y fallido.
Trazabilidad de consultas, accesos y modificaciones	RLFPDPPP 2011, art. 57; NOM-024-SSA3-2012, requisito funcional de trazabilidad	Registro de auditoría (audit log) inmutable que documenta cada consulta, modificación, descarga e intento de acceso fallido al expediente, con identificación del usuario, fecha, hora y acción realizada. Almacenado en AWS CloudTrail con retención mínima de cinco años conforme a NOM-004.

Nota. AES = Advanced Encryption Standard. TLS = Transport Layer Security. RBAC = Role-Based Access Control. MFA = Multi-Factor Authentication. Elaboración propia con base en las fuentes citadas en este capítulo.

Tabla 4: Trazabilidad normativa: de obligación legal a requerimiento técnico en NutriApp — Parte 2: Reglamento, NOMs y uso de nube.

Obligación legal	Fuente normativa	Requerimiento técnico en NutriApp
Inventario de datos, análisis de riesgos y análisis de brecha	RLFPDPPP 2011, art. 61	Catálogo de datos estructurado en AWS con clasificación por nivel de sensibilidad. Evaluación de impacto a la privacidad (Privacy Impact Assessment) documentada antes del despliegue en producción. Revisión semestral del análisis de brecha con registro de hallazgos y acciones correctivas.
Gestión de derechos ARCO en plazo legal	LFPDPPP 2025, arts. 28–35 (plazo máximo: 20 días hábiles para respuesta)	Módulo ARCO con flujo de solicitud, asignación, resolución y notificación automatizado. Registro de fecha de recepción, fecha de resolución y respuesta emitida. Alertas automáticas al nutriólogo cuando el plazo de respuesta está próximo a vencer. Historial de solicitudes accesible para auditoría.
Confidencialidad y conservación del expediente clínico	NOM-004-SSA3-2012 (conservación mínima de 5 años desde el último acto médico con confidencialidad durante todo ese período)	Políticas de retención de datos en Amazon S3 con ciclo de vida configurado al mínimo legal. Acceso al expediente restringido por roles y por relación activa con el paciente. Eliminación segura (secure deletion) al vencer el período de retención, con registro del evento de eliminación.
Cifrado, autenticación y trazabilidad en sistema de expediente clínico electrónico	NOM-024-SSA3-2012 (requerimientos funcionales obligatorios para todo sistema de ECE que adopte un establecimiento de salud)	Los tres requerimientos funcionales de la NOM-024 se cumplen de forma integrada a través de la arquitectura AWS: cifrado mediante AWS Key Management Service (KMS), autenticación mediante Amazon Cognito con MFA, y trazabilidad mediante AWS CloudTrail con logs inmutables. Ninguno de los tres requiere configuración adicional por parte del nutriólogo: son condiciones de operación predeterminadas de la plataforma.
Uso de proveedor	RLFPDPPP	Amazon Web Services con certificaciones

2.4.3. **Requerimientos que la ley mexicana no exige pero el estándar internacional sí: decisiones de diseño proactivas**

El análisis comparativo de este capítulo reveló tres ausencias en la LFPDPPP mexicana que los marcos más robustos de la región y del mundo sí contemplan: la portabilidad de datos, un plazo definido para la notificación de brechas y la figura del encargado interno de cumplimiento. NutriApp incorpora los tres elementos por diseño, no porque la ley mexicana lo exija, sino porque el estándar comparado indica que representan buenas prácticas verificables y porque su ausencia en la plataforma generaría una brecha innecesaria entre lo que el sistema ofrece y lo que el paciente tiene derecho a esperar en cualquier sistema de salud digital moderno.

- I. **Portabilidad de datos: el derecho que México no tiene pero NutriApp implementa.** Brasil lo exige en el artículo 18, fracción V de la LGPD. Uruguay lo reconoce en el artículo 14 de la Ley 18.331. El GDPR lo establece en su artículo 20. La LFPDPPP mexicana de 2025 no lo contempla explícitamente. NutriApp incorpora la portabilidad como funcionalidad nativa: el paciente puede solicitar en cualquier momento la exportación de su expediente completo en formato estructurado y estándar (PDF clínico y JSON para interoperabilidad con otros sistemas), sin que el nutriólogo pueda negarlo ni cobrarlo. Esta decisión de diseño anticipa la evolución probable del marco legal mexicano en esta materia y posiciona a NutriApp como una plataforma que ya cumple el estándar internacional sin esperar a que la ley local lo alcance.
- II. **Notificación de brechas en 72 horas: el plazo que la ley mexicana no define pero NutriApp sí.** Uruguay establece 72 horas por decreto. El GDPR establece 72 horas en su artículo 33. La LFPDPPP mexicana obliga a notificar pero sin plazo específico. NutriApp implementa un protocolo interno de respuesta a incidentes con un tiempo objetivo de notificación de 72 horas desde la detección de la brecha: notificación automática al nutriólogo, generación de un reporte del incidente con los datos afectados y el alcance estimado, y guía paso a paso para la notificación a la SABG y a los pacientes afectados. Este protocolo no sustituye la obligación legal del nutriólogo de notificar a la autoridad, pero la facilita y la hace operativamente viable para un profesional independiente que no tiene experiencia en gestión de incidentes de seguridad.
- III. **Encargado de cumplimiento: la figura que México no exige pero que NutriApp sugiere y apoya.** El GDPR europeo exige un Data Protection Officer para organizaciones que traten datos de salud a gran escala (GDPR, 2016, art. 37). Brasil exige un Encarregado de Proteção de Dados para todos los con-

troladores (LGPD, 2018, art. 41). La LFPDPPP mexicana no establece ninguna figura equivalente. NutriApp no puede crear por diseño una figura legal que la ley no exige, pero sí puede implementar dos mecanismos que cumplen la misma función práctica: primero, un panel de cumplimiento interno que consolida el estado de todos los expedientes, consentimientos vigentes, solicitudes ARCO pendientes y auditorías de acceso, de modo que el nutriólogo tenga en todo momento una vista completa de su posición de cumplimiento; segundo, una guía de mejores prácticas integrada en la plataforma que explica en lenguaje no legal qué debe hacer el nutriólogo ante cada situación regulatoria —una solicitud ARCO, una queja de un paciente, una auditoría de la autoridad— sin necesidad de contratar asesoría legal externa para cada evento.

Con esta subsección cierra el capítulo de Marco Normativo. El recorrido realizado — desde los antecedentes constitucionales de la LFPDPPP hasta la tabla de trazabilidad entre obligaciones legales y requerimientos técnicos— establece el fundamento sobre el que se construye NutriApp: no como una herramienta de gestión clínica que agrega privacidad como característica adicional, sino como un sistema diseñado desde su origen para que el cumplimiento normativo sea una consecuencia automática de su uso ordinario. Ese es el significado práctico de Privacy by Design aplicado al sector de la nutrición en México.

3. Diagnóstico: Situación Actual del Sector

3.1. Hábitos digitales del nutriólogo en México

3.1.1. Diseño de encuesta a nutriólogos

Encuesta 1: Diagnóstico de desconocimiento de la LFPDPPP

Encuesta 2: Levantamiento de requerimientos para el MVP

Encuesta 3: Validación de propuesta mediante wireframes/demo

3.1.2. Resultados y métricas base del problema

Resultados 1: Diagnóstico de desconocimiento de la LFPDPPP

Resultados 2: Levantamiento de requerimientos para el MVP

Resultados 3: Validación de propuesta mediante wireframes/demo

3.2. Estudio de mercado y competencia

3.2.1. Softwares actuales de nutrición en México

3.2.2. Benchmarking de seguridad: carencias de la competencia

3.2.3. Diferenciador de NutriApp

4. Marco de Referencia Técnico

4.1. Arquitectura en la nube: conceptos y estándares

4.2. Seguridad de datos: cifrado, MFA y trazabilidad

4.3. Privacy by Design: principios y aplicación práctica

4.4. Estándares internacionales aplicables (ISO/IEC 27001, HIPAA como referencia)

5. Metodología

5.1. Tipo de estudio y enfoque metodológico

5.2. Investigación documental: análisis normativo y benchmarking

5.2.1. Criterios de selección y revisión del marco legal

5.2.2. Criterios de benchmarking de software de nutrición

5.3. Investigación de campo: encuestas a nutriólogos

5.3.1. Población objetivo y criterios de inclusión

5.3.2. Diseño y validación de instrumentos

5.3.3. Procedimiento de aplicación y recolección de datos

5.3.4. Estrategia de análisis y triangulación

5.4. Diseño arquitectónico basado en evidencia

5.4.1. Trazabilidad: de requisito legal a decisión técnica

5.4.2. Alcance y limitaciones del diseño propuesto

5.5. Consideraciones éticas y confidencialidad

6. Diseño de la Solución

6.1. Infraestructura AWS: KMS, Cognito, Lambda, RDS

6.2. Diagramas de ingeniería

6.2.1. Diagrama de arquitectura de servicios

6.2.2. Diagramas UML: casos de uso y secuencia

6.2.3. Diagrama entidad-relación

7. Propuesta del Producto Mínimo Viable (MVP)

7.1. Requerimientos mínimos del sistema

7.2. Módulo de consentimiento digital y derechos ARCO

7.3. Justificación del alcance del MVP

8. Resultados y Análisis

8.1. Resultados de encuestas: evidencia del desconocimiento

8.2. Validación normativa del diseño propuesto

8.3. Análisis costo-beneficio: prevención de multas vs. costo operativo

9. Conclusiones

9.1. Comprobación de hipótesis

9.2. Lecciones aprendidas y recomendaciones para el gremio

9.3. Limitaciones del estudio y trabajo futuro

Referencias

- Código Penal Federal. (1931, 14 de agosto; última reforma 2024). *Diario Oficial de la Federación*. <https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf>
- Constitución Política de los Estados Unidos Mexicanos. (1917, 5 de febrero; reformada 2024). *Diario Oficial de la Federación*. <https://www.diputados.gob.mx/LeyesBiblio/pdf/CPEUM.pdf>
- Diario Oficial de la Federación. (2025, 22 de mayo). *Decreto por el que se reforman disposiciones del Reglamento Interior de la Secretaría Anticorrupción y Buen Gobierno*. DOF. <https://sidof.segob.gob.mx/notas/docFuente/5752650>
- Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales. (2021, 17 de abril). *Comunicado INAI/032/21: El expediente clínico constituye un dato personal sensible*. INAI. <https://home.inai.org.mx/wp-content/documentos/SalaDePrensa/Comunicados/Nota%20INAI-032-21.pdf>
- Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales. (2023a, 8 de enero). *Comunicado INAI/008/23: Multas impuestas en 2022 por infringir la LFPDPPP suman más de 60 mdp*. INAI. <https://home.inai.org.mx/wp-content/documentos/SalaDePrensa/Comunicados/Comunicado%20INAI-008-23.pdf>
- Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales. (2023b, 6 de agosto). *Comunicado INAI/230/23: Impone INAI multas por más de 11 mdp por infringir la LFPDPPP*. INAI. <https://home.inai.org.mx/wp-content/documentos/SalaDePrensa/Comunicados/Comunicado%20INAI-230-23.pdf>
- Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales. (2025). *Aviso de cierre del sitio institucional del INAI*. INAI. <https://home.inai.org.mx>
- Ley Federal de Protección de Datos Personales en Posesión de los Particulares. (2010, 5 de julio). *Diario Oficial de la Federación*. [Abrogada el 21 de marzo de 2025].

- Ley Federal de Protección de Datos Personales en Posesión de los Particulares. (2025, 20 de marzo; última reforma 14 de noviembre de 2025). *Diario Oficial de la Federación*. <https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf>
- Ley Federal de Transparencia y Acceso a la Información Pública Gubernamental. (2002, 11 de junio). *Diario Oficial de la Federación*. [Abrogada el 9 de mayo de 2016]. <https://www.diputados.gob.mx/LeyesBiblio/abro/lftaipg.htm>
- Ley General de Salud. (1984, 7 de febrero; última reforma 2024). *Diario Oficial de la Federación*. <https://www.diputados.gob.mx/LeyesBiblio/pdf/LGS.pdf>
- Ley Reglamentaria del Artículo 5° Constitucional, Relativo al Ejercicio de las Profesiones en el Distrito Federal. (1945, 26 de mayo; última reforma 2010). *Diario Oficial de la Federación*. <https://www.diputados.gob.mx/LeyesBiblio/pdf/RPro.pdf>
- Marván Laborde, M. (2023, 29 de abril). Del IFAI al INAI: la lucha por el derecho a saber. *El Sol de México*. <https://oem.com.mx/elsoldemexico/mexico/del-ifai-al-inai-la-lucha-por-el-derecho-a-saber-15857467>
- Norma Oficial Mexicana NOM-004-SSA3-2012, Del expediente clínico. (2012, 15 de octubre). *Diario Oficial de la Federación*.
- Norma Oficial Mexicana NOM-008-SSA3-2017, Para el tratamiento integral del sobrepeso y la obesidad. (2018, 18 de mayo). *Diario Oficial de la Federación*.
- Norma Oficial Mexicana NOM-024-SSA3-2012, Sistemas de información de registro electrónico para la salud. (2012, 30 de noviembre). *Diario Oficial de la Federación*.
- Organización para la Cooperación y el Desarrollo Económicos. (1980). *Directrices sobre la protección de la privacidad y los flujos transfronterizos de datos personales*. OCDE. <https://www.oecd.org/sti/ieconomy/oecdguidelinesontheprivacyand.htm>
- Organización para la Cooperación y el Desarrollo Económicos. (1994). *México en la OCDE*. OCDE. <https://www.oecd.org/mexico/>
- Reglamento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares. (2011, 21 de diciembre). *Diario Oficial de la Federación*. https://www.diputados.gob.mx/LeyesBiblio/regley/Reg_LFPDPPP.pdf
- Saludiarario. (2017, 28 de diciembre). INAI sanciona a médico por entregar a un tercero expediente clínico. *Saludiarario*. <https://www.saludiarario.com/inai-sanciona-a-medico-por-en>

- Saludiarario. (2018, 3 de enero). INAI sanciona a hospital por negar expediente clínico a paciente. *Saludiarario*. <https://www.saludiarario.com/inai-sanciona-a-hospital-por-negar-ex>
- Secretaría Anticorrupción y Buen Gobierno. (2025, 21 de marzo). La Secretaría Anticorrupción y Buen Gobierno reafirma su compromiso con la transparencia y la protección de datos personales. *Gobierno de México*. <https://www.gob.mx/buengobierno/prensa/la-secretaria-anticorrupcion-y-buen-gobierno-reafirma-su-compromiso-con-l>
- Lei n° 13.709, de 14 de agosto de 2018 (Lei Geral de Proteção de Dados Pessoais). (2018, 14 de agosto; vigente desde 18 de septiembre de 2020). *Diário Oficial da União*. https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- Emenda Constitucional n° 115. (2022, 10 de febrero). Inclui a proteção de dados pessoais entre os direitos e garantias fundamentais. *Diário Oficial da União*. https://www.planalto.gov.br/ccivil_03/constituicao/emendas/emc/emc115.htm
- Conselho Federal de Medicina. (2022, 4 de noviembre). *Resolução CFM n° 2.314/2022: Define e regulamenta a telemedicina no Brasil*. CFM. <https://www.in.gov.br/en/web/dou/-/resolucao-cfm-n-2.314-2022-395326630>
- Ley 18.331, de Protección de Datos Personales y Acción de Habeas Data. (2008, 11 de agosto). *Diario Oficial de la República Oriental del Uruguay*. <https://www.imo.com.uy/bases/leyes/18331-2008>
- Decreto N° 414/009, Reglamentación de la Ley 18.331 relativa a la protección de datos personales. (2009, 31 de agosto). *Diario Oficial de la República Oriental del Uruguay*. <https://www.imo.com.uy/bases/decretos/414-2009>
- Decreto N° 242/017, Historia Clínica Electrónica Nacional. (2017, 11 de septiembre). *Diario Oficial de la República Oriental del Uruguay*. <https://www.imo.com.uy/bases/decretos/242-2017>
- Ministerio de Salud Pública del Uruguay. (2017). *Ordenanza N° 1085/2017: Sistema de Historia Clínica Electrónica Nacional*. MSP Uruguay. <https://www.gub.uy/ministerio-salud-publica>
- Health Insurance Portability and Accountability Act of 1996. (1996). *Public Law 104-191*. U.S. Government Publishing Office. <https://www.govinfo.gov/content/pkg/PLAW-104publ191/pdf/PLAW-104publ191.pdf>
- U.S. Department of Health and Human Services. (2013). *HIPAA Administrative Sim-*

plification: Regulation Text (45 CFR Parts 160, 162 and 164). HHS. <https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/combined/hipaa-simplification-201303.pdf>

- Health Information Technology for Economic and Clinical Health Act. (2009). *Public Law 111-5, Division A, Title XIII*. U.S. Government Publishing Office. <https://www.govinfo.gov/content/pkg/PLAW-111publ5/pdf/PLAW-111publ5.pdf>
- California Consumer Privacy Act. (2018). *California Civil Code § 1798.100 et seq.* California Legislative Information. https://leginfo.legislature.ca.gov/faces/codes_displaySection.xhtml?sectionNum=1798.100.&lawCode=CIV
- Washington State Legislature. (2023). *My Health My Data Act* (RCW 70.372). Washington State Legislature. <https://app.leg.wa.gov/RCW/default.aspx?cite=70.372>
- U.S. Department of Health and Human Services. (2025, 6 de enero). *HIPAA Security Rule to Strengthen the Cybersecurity of Electronic Protected Health Information* (Proposed Rule, 90 FR 898). Federal Register. <https://www.federalregister.gov/documents/2025/01/06/2024-29903/hipaa-security-rule-to-strengthen-the-cyberse>
- Parlamento Europeo y Consejo de la Unión Europea. (2016, 27 de abril). *Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos* (GDPR). *Diario Oficial de la Unión Europea*, L 119, 1–88. <https://eur-lex.europa.eu/legal-content/ES/TXT/PDF/?uri=CELEX:32016R0679>
- Bundesdatenschutzgesetz. (2018, 30 de junio; última reforma 2021). *Bundesgesetzblatt*, Teil I, Nr. 44. https://www.gesetze-im-internet.de/bdsg_2018/BDSG.pdf
- Patientendatenschutzgesetz. (2020, 14 de octubre). *Bundesgesetzblatt*, Teil I, Nr. 46, 2115–2145. https://www.bgbl.de/xaver/bgbl/start.xav?startbk=Bundesanzeiger_BGBI&jumpTo=bgbl120s2115.pdf
- Digitalgesetz. (2024, 22 de marzo). *Gesetz zur Beschleunigung der Digitalisierung des Gesundheitswesens*, Artikel 1, § 393 SGB V. *Bundesgesetzblatt*, Nr. 101. https://www.bgbl.de/xaver/bgbl/start.xav?startbk=Bundesanzeiger_BGBI&jumpTo=bgbl124s0101.pdf
- Bundesamt für Sicherheit in der Informationstechnik. (2020). *Cloud Computing Com-*

pliance Criteria Catalogue (C5): Criteria to Assess the Information Security of Cloud Services. BSI. https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/CloudComputing/ComplianceCriteriaCloud/ComplianceCriteriaCloud_C5.pdf

- Cavoukian, A. (2009). *Privacy by design: The 7 foundational principles*. Information and Privacy Commissioner of Ontario. <https://www.ipc.on.ca/wp-content/uploads/resources/7foundationalprinciples.pdf>

Anexos